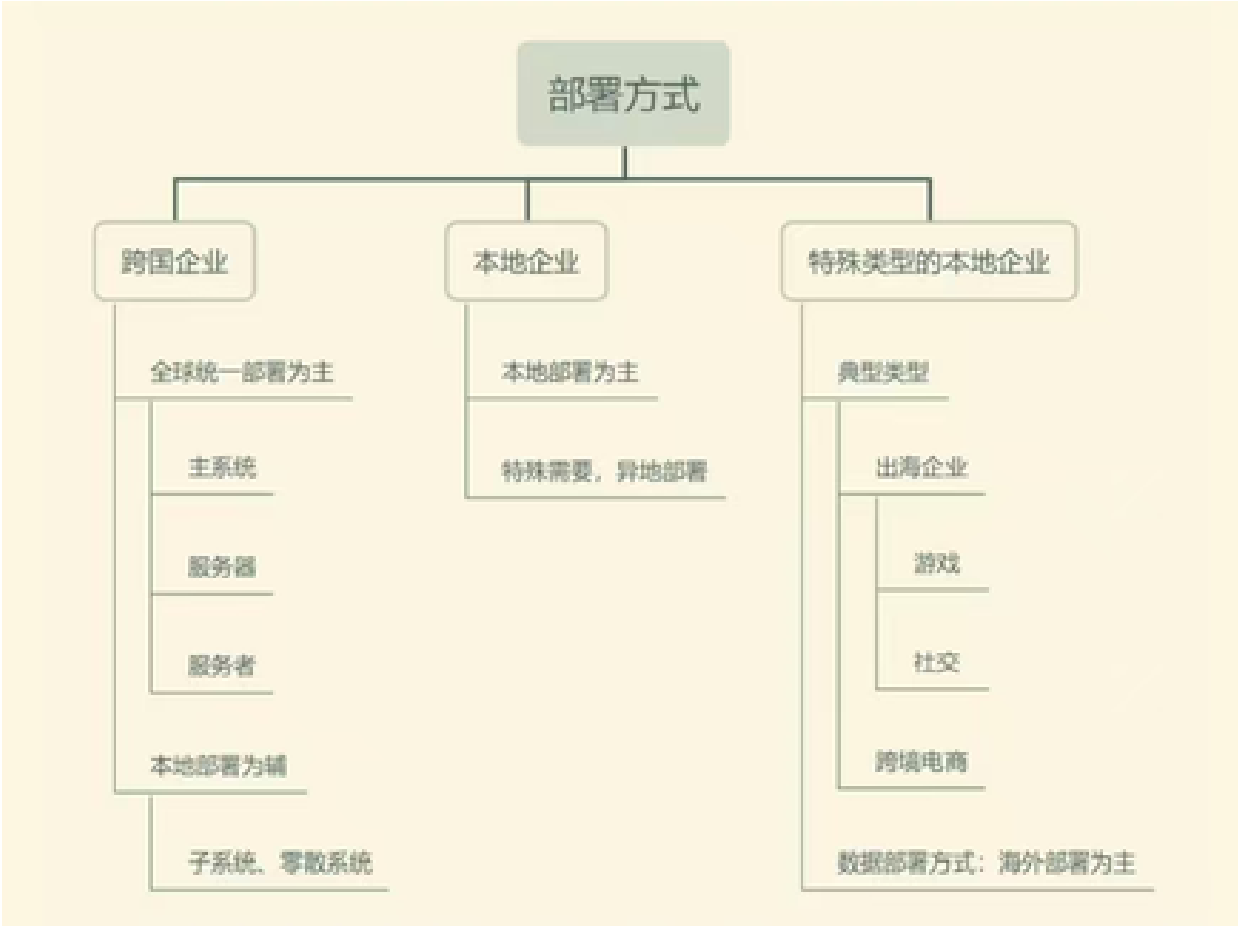


整体统筹开发文档

- 总体思路框架：
- 1.项目是什么？为什么要搞这个？
 - 2.合的是什么规？企业开展有关业务真实流程和场景？企业面临的风险和挑战？AI对此能做些什么？
 - （1）中国：*法律有哪些？*什么是跨境？*企业应当怎么做（流程/工具）？*企业在此过程中须遵守的具体条款/可能有的合规风险？*企业在此过程中面临的主要问题。*AI能做什么？
 - （2）欧盟：*法律有哪些？*什么是跨境？*企业应当怎么做（流程/工具）？*企业在此过程中须遵守的具体条款/可能有的合规风险？*企业在此过程中面临的主要问题。*AI能做什么？
 - （3）美国：*法律有哪些？*什么是跨境？*企业应当怎么做（流程/工具）？*企业在此过程中须遵守的具体条款/可能有的合规风险？*企业在此过程中面临的主要问题。*AI能做什么？
 - 3.产品的设计

二、企业现在是怎么做的？合的是什么规？具体场景是什么？

（一）企业（跨境）数据流动的具体场景

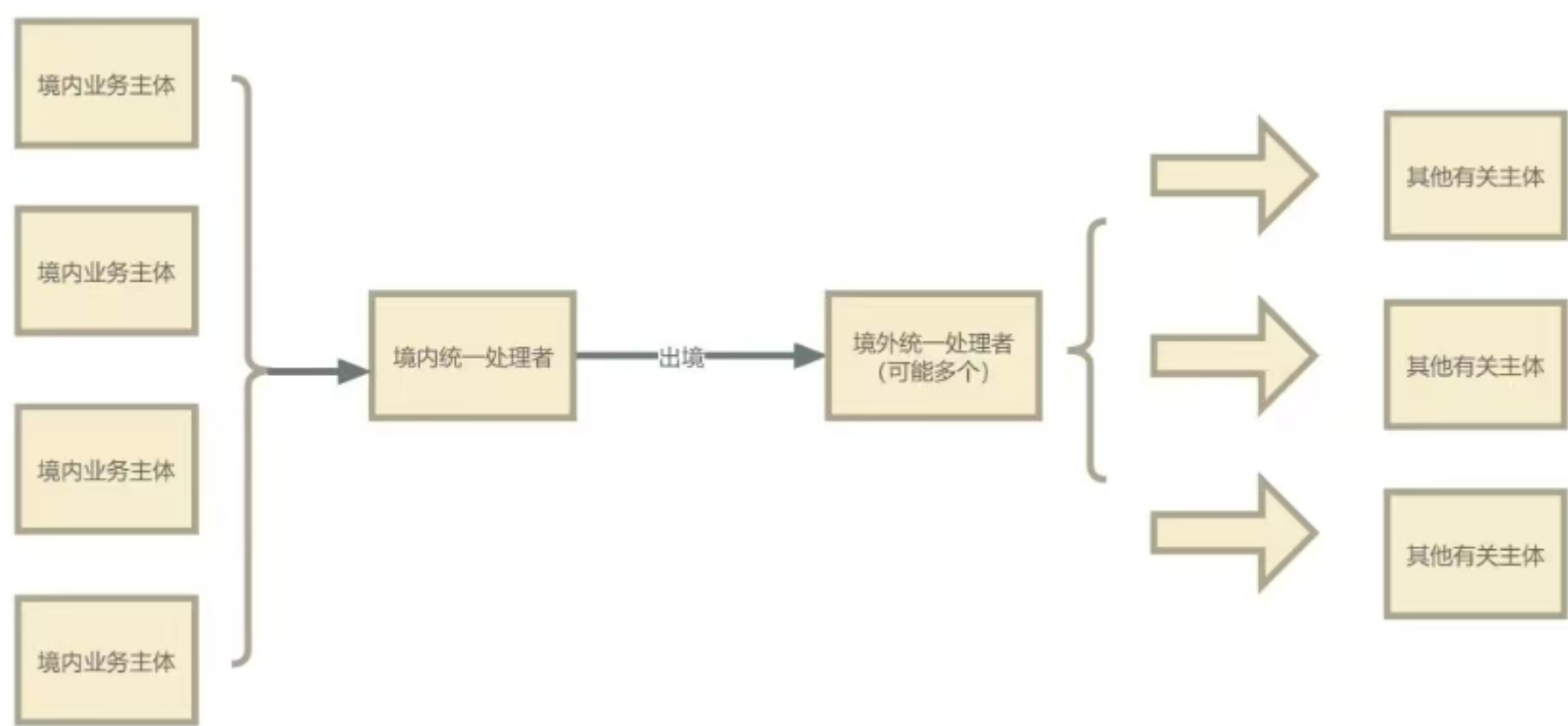


- （1）部署方式（跨国企业）
- 以全球统一的数据和IT部署为主：主系统、服务器、服务者
- 比如，很多跨国企业在中国的分公司、子公司、合资公司会在中国收集很多数据和个人信息，如员工信息、供应商信息、联系人信息。这些数据往往不会部署在每一个全球分布的国家或地区，会被部署在全球统一的一个或几个数据中心当中（也就是主系统），服务器也会在全球一个或多个地方部署。在东亚一般是在新加坡或香港部署。运行和维护的主系统和服务器的服务者也是会挑选一个IT service company；
- 以本地的数据和IT部署为辅
- 比如，在中国相对辅助、零散的系统，或者某个特别项目的服务器有可能部署在中国。
- 所以，由于跨国企业统一部署为主的特点，这些信息自然而然地就传输到了境外的服务器了，这是常态。

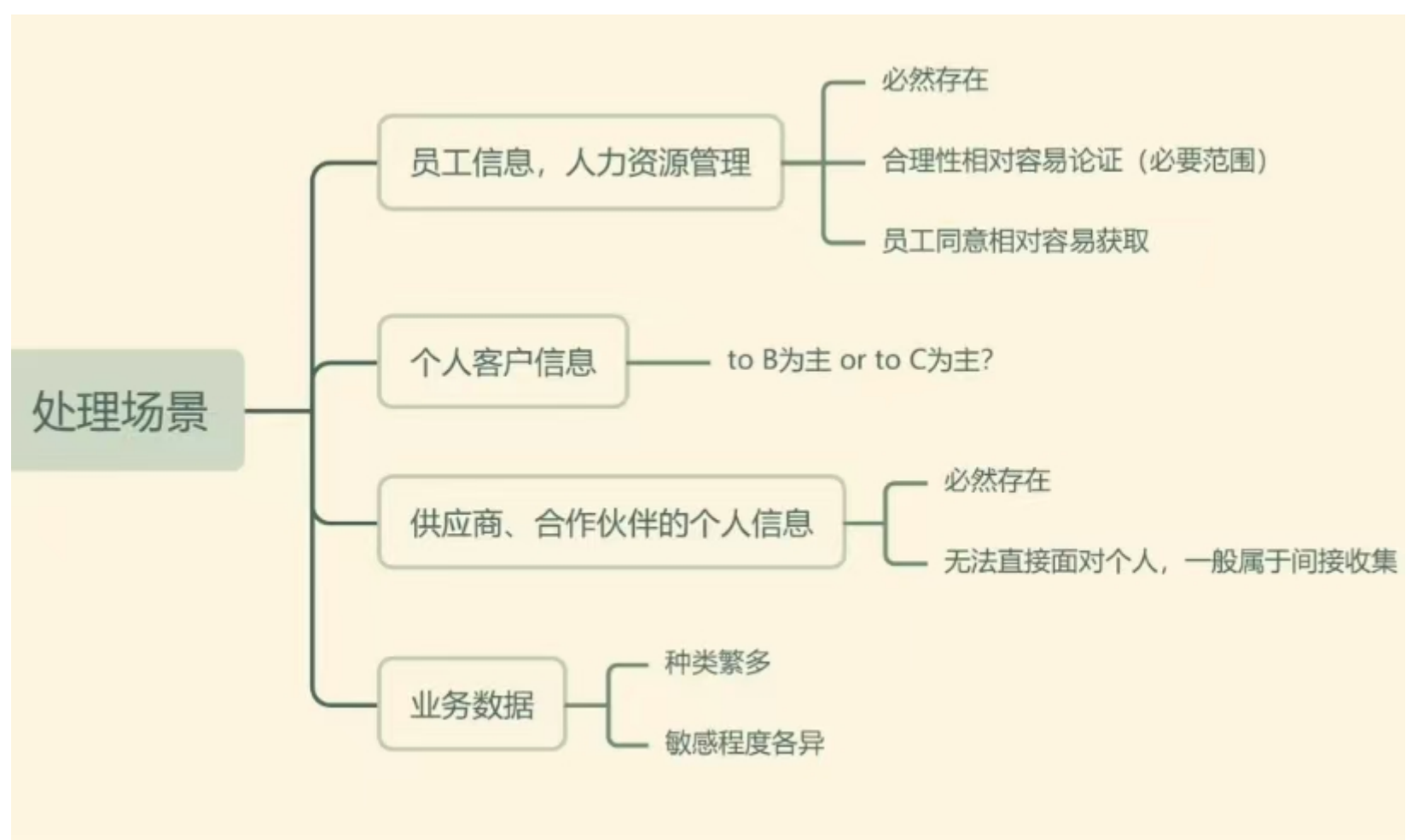
也有例外，苹果很多中国的数据和个人信息储存在云上贵州。

(2) 数据发出方和数据接收方的概况

- “数据发出方”一般是多汇一：在中国，很多情景是几十个子公司的数据往往会作为一个数据处理集群，在集团层面统一在中国境内做数据处理和个人信息处理，决定策略、收集什么、传输什么、传到境外传输给谁、境内外合同谁来签、合同条款和权利义务约束是怎么样、对我境内数据和个人信息的保护及对主体权利的保护遵从什么原则等等，是由同一帮同事去处理。很少有子公司各自为政。
- “数据接收方”可能是统一的一个（比如有一个公司汇总全世界很多国家传输来的数据和个人信息，统一处理，再对于子公司或关联方进行分发），也可能是多个接收方，比如给东亚、欧洲、美国都传输进行传输。



(3) 有以下四种常见的出境信息



处理上述个人信息必须要有合法性基础。

《个人信息保护法》第十三条 符合下列情形之一的，个人信息处理者方可处理个人信息：

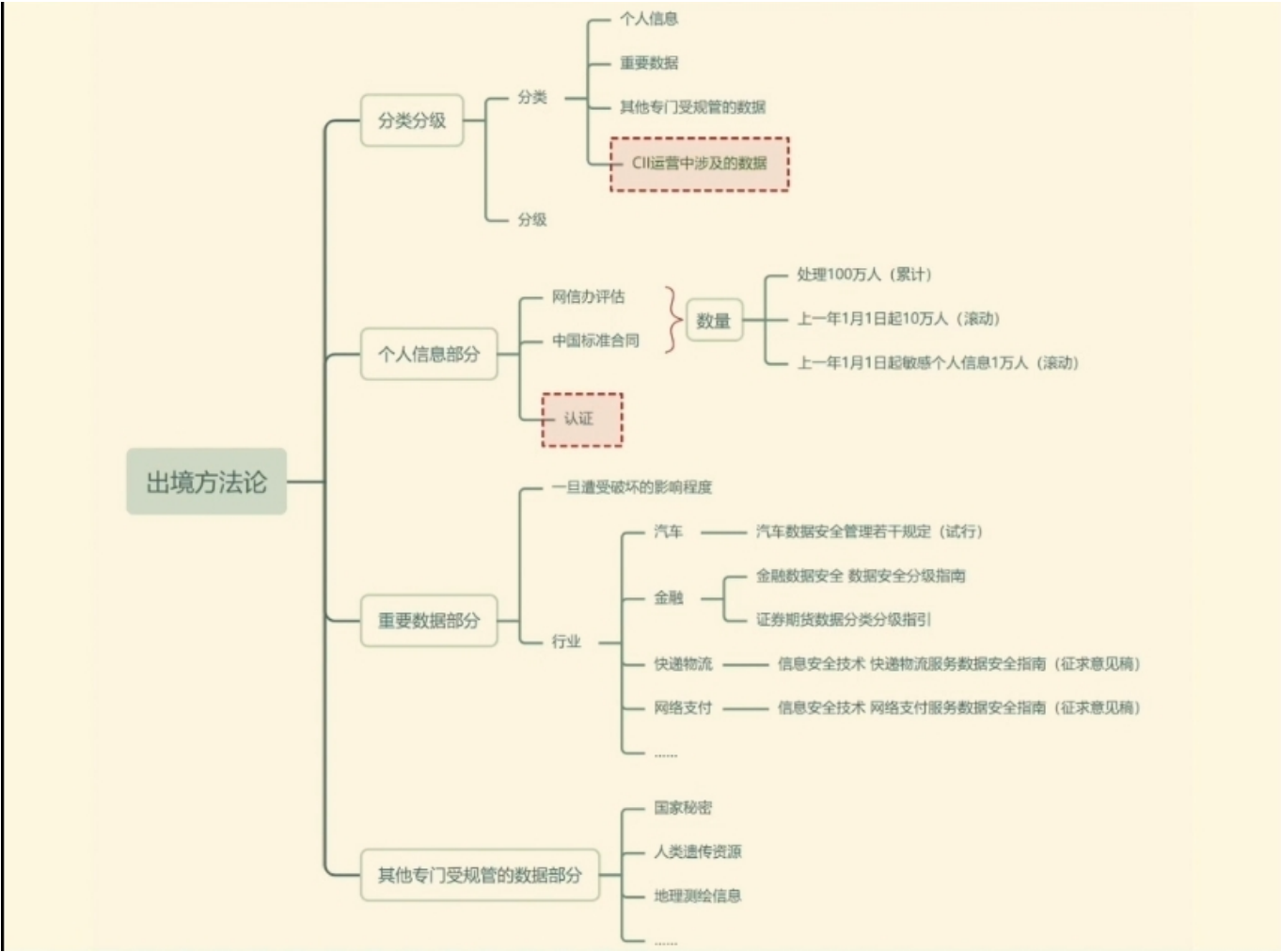
- (一) 取得个人的同意；
- (二) 为订立、履行个人作为一方当事人的合同所必需，或者按照依法制定的劳动规章制度和依法签订的集体合同实施人力资源管理所必需；
- (三) 为履行法定职责或者法定义务所必需；
- (四) 为应对突发公共卫生事件，或者紧急情况下为保护自然人的生命健康和财产安全所必需；
- (五) 为公共利益实施新闻报道、舆论监督等行为，在合理的范围内处理个人信息；
- (六) 依照本法规定在合理的范围内处理个人自行公开或者其他已经合法公开的个人信息；
- (七) 法律、行政法规规定的其他情形。

依照本法其他有关规定，处理个人信息应当取得个人同意，但是有前款第二项至第七项规定情形的，不需取得个人同意。

员工信息容易论证合法性：

供应商、合作伙伴不好论证：因为不直接面对个人，有时候外包场景下属于间接收集。比如从供应商处收集其员工的姓名、履历等信息，此时企业无法向这些个人去获取同意的，需要企业和供应商签署业务保护条款。

(4) 出境方法



分类：个人信息、重要数据、其他专门受规管的数据、CII运营中心涉及的数据（企业不知道一般就不是）

分级：根据行业不同

①个人信息部分：

《个人信息保护法》第三十八条 个人信息处理者因业务等需要，确需向中华人民共和国境外提供个人信息的，应当具备下列条件之一：

- (一) 依照本法第四十条的规定通过国家网信部门组织的安全评估；
- (二) 按照国家网信部门的规定经专业机构进行个人信息保护认证；
- (三) 按照国家网信部门制定的标准合同与境外接收方订立合同，约定双方的权利和义务；
- (四) 法律、行政法规或者国家网信部门规定的其他条件。

中华人民共和国缔结或者参加的国际条约、协定对向中华人民共和国境外提供个人信息的条件等有规定的，可以按照其规定执行。

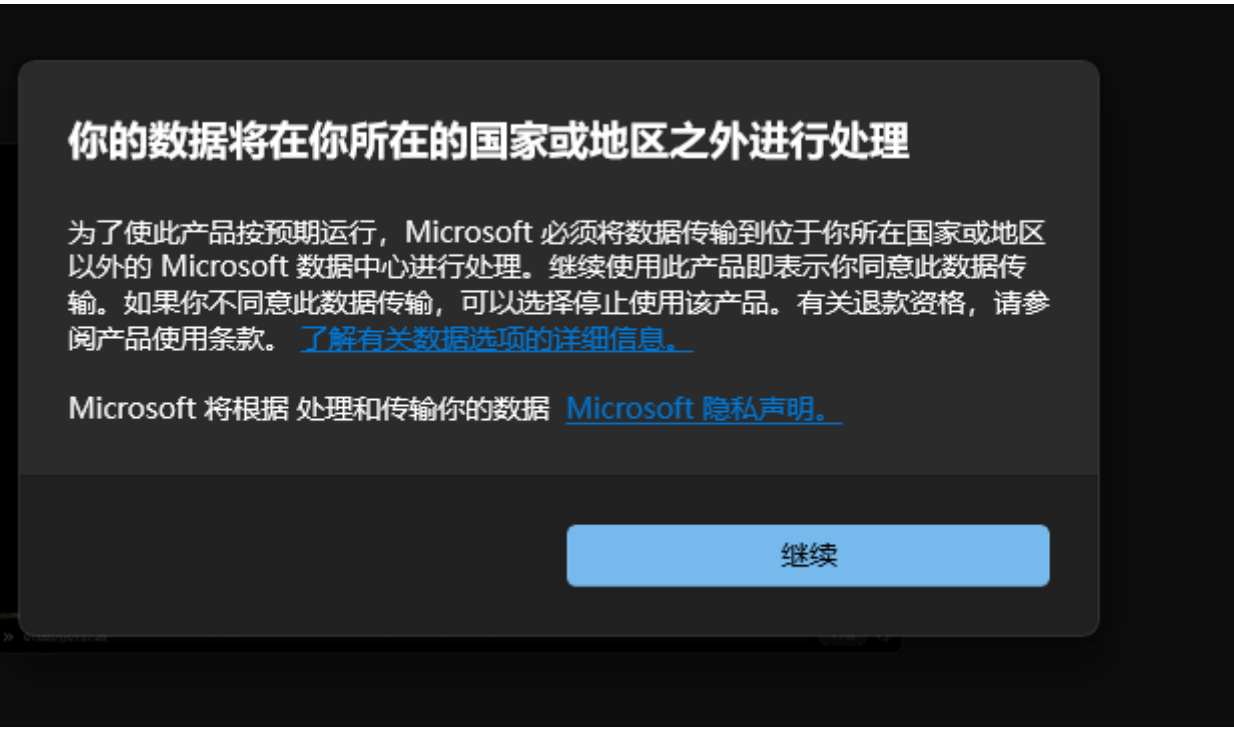
个人信息处理者应当采取必要措施，保障境外接收方处理个人信息的活动达到本法规定的个人信息保护标准。

第三十九条 个人信息处理者向中华人民共和国境外提供个人信息的，应当向个人告知境外接收方的名称或者姓名、联系方式、处理目的、处理方式、个人信息的种类以及个人向境外接收方行使本法规定权利的方式和程序等事项，并取得个人的单独同意。

同意-告知

☑ 线上实践实例

☑ 线下实践实例



②重要数据部分

需要看行业的标准、指南，参照性地识别重要数据。

《数据安全法》第二十一条 国家建立数据分类分级保护制度，根据数据在经济社会发展中的重要程度，以及一旦遭到篡改、破坏、泄露或者非法获取、非法利用，对国家安全、公共利益或者个人、组织合法权益造成的危害程度，对数据实行分类分级保护。国家数据安全工作协调机制统筹协调有关部门制定重要数据目录，加强对重要数据的保护。

关系国家安全、国民经济命脉、重要民生、重大公共利益等数据属于国家核心数据，实行更加严格的管理制度。

各地区、各部门应当按照数据分类分级保护制度，确定本地区、本部门以及相关行业、领域的重要数据具体目录，对列入目录的数据进行重点保护。

（二）各国家/地区数据跨境法律框架

以下简单介绍各国数据执法的实践，选取的司法辖区也是近几年执法较为活跃的国家或地区，执法活跃度一定程度上也代表了法律服务的需求量，我们可以考虑将这些国家或地区作为我们服务的主要司法辖区。

1.中国框架

我国《个人信息保护法》《数据安全法》《网络安全法》及《出境评估办法》主要限制重要数据、个人信息出境。尤其《出境评估办法》，适用范围明确限于重要数据和个人信息出境。不涉及该两类数据的，目前我国生效法律法规中没有明确的出境限制。



Q：在我国，什么是出境？

A：

根据网信办于2026年1月发布《数据出境安全评估申报指南（第三版）》https://www.szaicx.com/page142?article_id=19415

下面三种行为属于数据出境行为：

- 数据处理者将在境内运营中收集和产生的数据传输至境外；
- 数据处理者收集和产生的数据存储在境内，境外的机构、组织或者个人可以查询、调取、下载、导出；
- 符合《个人信息保护法》第三条第二款情形，在境外处理境内自然人个人信息等其他数据处理活动。

📖 Q：将中国的数据传导域外有哪些法律路径？

A：

- ①数据出境安全评估
- ②个人信息出境认证
- ③个人信息出境标准合同备案

顺序：理论上，如果不属于需要安全评估的情形，那么在实施个人信息出境时，既可选择个人信息保护认证途径，也可选择标准合同途径。具体如何选择并不强制，由数据出境方根据实际情况自行决定。

路径一：数据出境安全评估

适用条件

《数据出境安全评估办法》所称数据出境活动主要包括：一是数据处理者将在境内运营中收集和产生的数据传输、存储至境外。二是数据处理者收集和产生的数据存储在境内，境外的机构、组织或者个人可以访问或者调用。

2024年，《规范和促进数据跨境流动规定》明确了两种应当申报数据出境安全评估的条件：一是关键信息基础设施运营者向境外提供个人信息或者重要数据。二是关键信息基础设施运营者以外的数据处理者向境外提供重要数据，或者自当年1月1日起累计向境外提供100万人以上个人信息（不含敏感个人信息）或者1万人以上敏感个人信息。

有效期

《规范和促进数据跨境流动规定》将通过数据出境安全评估结果的有效期由《数据出境安全评估办法》中规定的2年延长至3年，自评估结果出具之日起计算。同时，增加数据处理者可以申请延长评估结果有效期的规定。有效期届满，需要继续开展数据出境活动且未发生需要重新申报数据出境安全评估情形的，数据处理者可以在有效期届满前60个工作日内通过所在地省级网信部门向国家网信部门提出延长评估结果有效期申请。经国家网信部门批准，可以延长评估结果有效期3年。

办理途径

登录数据出境申报系统，网址：<https://sjcj.cac.gov.cn>。

关键信息基础设施运营者或者其他不适合通过数据出境申报系统申报数据出境安全评估的，采用线下方式通过所在地省级网信部门向国家网信部门申报数据出境安全评估。

逐步上传填写方式：

— 数据出境安全评估 —

当前用户：数据处理者 -  退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

1

数据处理者情况

2

法定代表人信息

3

数据安全负责人和管理机构信息

4

经办人信息

5

数据处理者遵守中国法律、行政
法规、部门规章情况

6

数据出境场景

7

数据出境安全评估申报材料上传

数据处理者向境外提供数据，有下列情形之一的，应当通过所在地省级网信部门向国家网信办申报数据出境安全评估

☒（一）关键信息基础设施运营者向境外提供个人信息或者重要数据；

☒（二）关键信息基础设施运营者以外的数据处理者向境外提供重要数据，或者自当年1月1日起累计向境外提供100万人以上个人信息（不含敏感个人信息）或者1万人以上敏感个人信息；

— 数据出境安全评估 —

当前用户：数据处理者 -  退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

1

数据处理者情况

2

法定代表人信息

3

数据安全负责人和管理机构信息

4

经办人信息

5

数据处理者遵守中国法律、行政
法规、部门规章情况

6

数据出境场景

7

数据出境安全评估申报材料上传

数据处理者情况

* 单位名称

* 单位性质

其他

请输入单位性质（其他）

* 单位类型

其他

请输入单位类型（其他）

* 统一社会信用代码

单位注册地

* 办公所在地

* 是否为关键信息基础设施运营者

员工数量

员工数量单位

* 处理个人信息规模

* 处理个人信息规模单位

— 数据出境安全评估 —

当前用户：数据处理者 -  退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

1

数据处理者情况

2

法定代表人信息

3

数据安全负责人和管理机构信息

4

经办人信息

5

数据处理者遵守中国法律、行政
法规、部门规章情况

6

数据出境场景

7

数据出境安全评估申报材料上传

法定代表人信息

* 姓名

* 联系电话

* 国籍

* 职务

* 证件类型

其他

请输入证件类型（其他）

* 证件号码

* 电子邮箱

— 数据出境安全评估 —

当前用户：数据处理者 -  | 退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

① 数据处理者情况

② 法定代表人信息

③ 数据安全负责人和管理机构信息

④ 经办人信息

⑤ 数据处理者遵守中国法律、行政
法规、部门规章情况

⑥ 数据出境场景

⑦ 数据出境安全评估申报材料上传

数据安全负责人和管理机构信息

* 姓名

请输入数据安全负责人姓名

* 联系电话

请输入数据安全负责人联系电话，如+86-01012345678

* 国籍

请选择国籍

* 职务

请输入数据安全负责人职务

* 证件类型

请选择证件类型

其他

请输入证件类型（其他）

* 证件号码

请输入证件号码

* 管理机构名称

请输入管理机构名称

* 管理机构人数

请输入管理机构人数

* 管理机构人数单位

请选择单位

电子邮箱

请输入电子邮箱

— 数据出境安全评估 —

当前用户：数据处理者 -  | 退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

① 数据处理者情况

② 法定代表人信息

③ 数据安全负责人和管理机构信息

④ 经办人信息

⑤ 数据处理者遵守中国法律、行政
法规、部门规章情况

⑥ 数据出境场景

⑦ 数据出境安全评估申报材料上传

经办人信息

* 姓名

* 联系电话

* 国籍

* 职务

* 证件类型

居民身份证

其他

请输入证件类型（其他）

* 证件号码

* 电子邮箱

— 数据出境安全评估 —

当前用户：数据处理者 -  | 退出

新建数据出境安全评估申报项目

注意事项：1.其他申报材料内容应与申报表内容保持一致。2.申报表06项应按场景分项描述，可根据实际申报的出境场景数量增加申报表06项，出境个人信息涉及自然人范围一致的场景应当合并。3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表06项境外接收方情况可填写统计数据。

数据出境安全评估申报适用情形

① 数据处理者情况

② 法定代表人信息

③ 数据安全负责人和管理机构信息

④ 经办人信息

⑤ 数据处理者遵守中国法律、行政
法规、部门规章情况

⑥ 数据出境场景

⑦ 数据出境安全评估申报材料上传

数据处理者遵守中国法律、行政法规、部门规章情况

* 数据处理者遵守中国法律、行政法规、部门规章情况

简述近2年在业务经营活动中受到行政处罚和有关主管部门调查及整改情况，重点说明数据和网络安全方面相关情况

1

请输入联系方式-邮箱

所在地

请输入所在地

添加境外接收方情况

添加数据出境场景

本单位承诺：
☒ 申报材料所有内容真实、完整、准确和有效。为国家网信办组织实施的数据出境安全评估工作提供必要的配合和支持。自评估工作为申报之日起3个月内完成，且至申报之日未发生重大变化。若承诺不实或者违背承诺，愿意承担相应法律责任。

上一步

返回

暂存

下一步

1

2

3

4

5

6

7

数据出境安全评估申报适用情形

数据处理者情况

法定代表人信息

数据安全负责人和管理机构信息

经办人信息

数据处理者遵守中国法律、行政
法规、部门规章情况

数据出境场景

数据出境安全评估申报材料上传

文件上传

*统一社会信用代码证件影印件（加盖公章）：

文件上传

*法定代表人身份证件影印件（加盖公章）：

文件上传

*经办人身份证件影印件（加盖公章）：

文件上传

*经办人授权委托书：

文件上传

*与境外接收方拟订立的数据出境相关合同或者
其他具有法律效力的文件影印件（加盖公章）：

文件上传

*数据出境风险自评估报告：

文件上传

《经办人授权委托书》模板下载

《数据出境风险自评估报告》模板下载

请上传《经办人授权委托书》签字并加盖公章的影印件

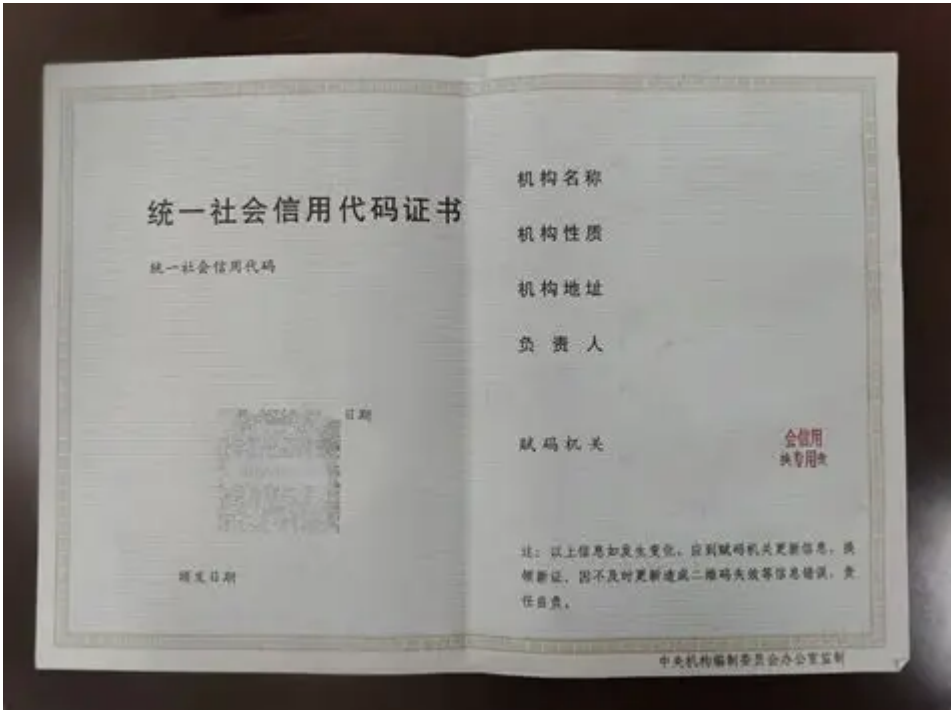
请上传《个人信息出境标准合同》加盖公章的影印件

请上传《数据出境风险自评估报告》加盖公章的影印件

其他相关材料

批量上传方式以下材料：

统一社会信用代码证件（例图）



法定代表人身份证件、经办人身份证件（例图）

数据出境安全评估申报表（模板）

1 数据处理器情况	单位名称			
	单位性质	☐ 政府部门 ☐ 事业单位 ☐ 企业 ☐ 社会组织 ☐ 其他		
	单位类型	☐ 内资 ☐ 外资 ☐ 中外合资 ☐ 港澳台资 ☐ 其他		
	单位注册地		办公所在地	
	员工数量		统一社会信用代码	
	是否为关键信息基础设施运营者	☐ 是 ☐ 否	处理个人信息规模	按自然人（去重）统计数量
2 法定代表人信息	姓名		职务/国籍	
	联系电话		电子邮箱	
	证件类型	☐ 居民身份证 ☐ 护照 ☐ 台湾居民来往大陆通行证 ☐ 港澳居民来往内地通行证 ☐ 其他		
	证件号码			
3 数据安全负责人和管理机构信息	姓名		职务/国籍	
	联系电话		电子邮箱	
	证件类型	☐ 居民身份证 ☐ 护照 ☐ 台湾居民来往大陆通行证 ☐ 港澳居民来往内地通行证 ☐ 其他		
	证件号码			
	管理机构名称		管理机构人数	
4 经办人信息	姓名		职务/国籍	
	联系电话		电子邮箱	
	证件类型	☐ 居民身份证 ☐ 护照 ☐ 台湾居民来往大陆通行证 ☐ 港澳居民来往内地通行证 ☐ 其他		

	证件号码			
5 数据处理器遵守中国法律、行政法规、部门规章情况	简述近 2 年在业务经营活动中受到行政处罚和有关主管监管部门调查及整改情况，重点说明数据和网络安全方面相关情况			
	出境场景简述	据实填写此次申报的数据出境场景业务、数据出境目的、数据出境方式等，应与法律文件中涉及业务名称一致，不超过 100 字（数据出境方式参考：公共互联网传输、跨境专线传输、公共互联网远程访问、跨境专线远程访问等）		
		数据出境数据情况	数据类型	☐ 重要数据 重要数据认定主管部门名称
	涉及行业/领域		☐ 工业 ☐ 电信 ☐ 交通 ☐ 金融 ☐ 自然资源 ☐ 卫生健康 ☐ 教育 ☐ 科技 ☐ 能源 ☐ 国防科工 ☐ 文旅 ☐ 跨境电商 ☐ 零售 ☐ 互联网 ☐ 其他	
	涉及自然人（去重）数量	包括当年已出境数量、未来三年出境数量以及两者的关系	涉及重要数据规模	MB/GB/TB
		境外接收方情况	境外接收方名称	
	所在国家或者地区			
	所在地址			
	主营业务			
	负责人姓名			负责人职务
联系方式	☐ 电话： ☐ 邮箱：			
统计说明：（如需）				

6 数据出境场景 2	
6 数据出境场景 3	
本单位承诺： ☐ 申报材料所有内容真实、完整、准确和有效。为国家网信办组织实施的数据出境安全评估工作提供必要的配合和支持。自评估工作为申报之日前 3 个月内完成，且至申报之日未发生重大变化。若承诺不实或者违背承诺，愿意承担相应法律责任。	

- 注：1.自评估报告内容应与申报表内容保持一致。
- 2.申报表第 6 项应按场景分项描述，可根据实际申报的出境场景数量增加申报表第 6 项。
- 3.境外接收方数量众多、范围不确定、无法逐一列举的，申报表第 6 项境外接收方情况可填写统计数据。
- 4.申报表严格按照模板填写，必须使用中文填写，字体四号“仿宋”，数字、字母统一使用四号“Times New Roman”字体，行距固定值 16 磅，段落首行缩进 2 字符。页面设置：A4 纸，上下页边距为 2.54cm，左右页边距为 3.18cm。

数据出境相关合同或者其他具有法律效力的文件

为了确保境外接收方处理个人信息的活动达到中华人民共和国相关法律法规规定的个人信息保护标准，明确个人信息处理者和境外接收方个人信息保护的义务和责任，双方经协商一致，特签订本合同，以便共同遵守。

个人信息处理者： _____

地址： _____

电话： _____ 邮箱： _____

联系人： _____ 职务： _____ 国籍： _____

境外接收方： _____

地址： _____

电话： _____ 邮箱： _____

联系人： _____ 职务： _____ 国籍： _____

数据出境风险自评估报告扫描件（这是我们可以重点参与的环节）

数据出境风险自评估报告（模板）

数据处理者名称： （盖章）

年 月 日

 数据出境风险自评估报告（模板）.docx

预评估

组织北京、天津、上海、江苏、浙江、广东等6地省级网信办试点开展数据出境安全预评估，央地协同提升安全评估效率。【来源：《《促进和规范数据跨境流动规定》实施一周年 数据出境安全管理工作取得积极成效》】

例如北京：正式提交申报材料前，企业可将申报材料提交至北京市数据跨境便利化服务平台进行线上预审核。平台地址：<https://sjcj.bjcert.org.cn>。

数据出境合规路径导引

1、请选择是否符合以下情形：

- ☐

（一）国际贸易、跨境运输、学术合作、跨国生产制造和市场营销等活动中收集和产生的数据向境外提供，不包含个人信息或者重要数据的。

（二）数据处理者在境外收集和产生的个人信息传输至境内处理后向境外提供，处理过程中没有引入境内个人信息或者重要数据的。

（三）数据处理者向境外提供个人信息，但不包括重要数据，符合下列条件之一的：

（1）为订立、履行个人作为一方当事人的合同，如跨境购物、跨境寄递、跨境汇款、跨境支付、跨境开户、机票酒店预订、签证办理、考试服务等，确需向境外提供个人信息的；

（2）按照依法制定的劳动规章制度和依法签订的集体合同实施跨境人力资源管理，确需向境外提供员工个人信息的；

（3）紧急情况下为保护自然人的生命健康和财产安全，确需向境外提供个人信息的；

（4）关键信息基础设施运营者以外的数据处理者自当年1月1日起累计向境外提供不满10万人个人信息（不含敏感个人信息）的；

☒

（四）如不符合以上豁免情形，请选择此项。
- [下一步](#)
- 我们在这个路径中，可以做的是：助力企业起草[数据出境风险自评估报告](#)
- ### 路径二：个人信息出境认证
- 主要依据：《[个人信息出境认证办法](#)》、GB/T 46068《数据安全技术个人信息跨境处理活动安全认证要求》
-
- GBT+46068-2025.pdf
 1.03MB
-
- #### 适用条件
- 个人信息处理者通过个人信息出境认证的方式向境外提供个人信息的，应当同时符合下列情形：
- （一）非关键信息基础设施运营者；

（二）自当年1月1日起累计向境外提供10万人以上、不满100万人个人信息（不含敏感个人信息）或者不满1万人敏感个人信息。
- 前款所称向境外提供的个人信息，不包括重要数据。
- 法律、行政法规或者国家网信部门另有规定的，从其规定。
- 个人信息处理者不得采取数量拆分等手段，将依法应当通过出境安全评估的个人信息通过个人信息出境认证的方式向境外提供。
- #### 审查评估内容
- 个人信息处理者在申请认证向境外提供个人信息前，应当按照法律、行政法规的规定履行告知、取得个人单独同意、进行个人信息保护影响评估等义务。个人信息保护影响评估重点评估以下内容：
- （一）个人信息处理者和境外接收方处理个人信息的目的、范围、方式等的合法性、正当性、必要性；

（二）出境个人信息的规模、范围、种类、敏感程度，个人信息出境可能对国家安全、公共利益、个人信息权益带来的风险；

（三）境外接收方承诺承担的义务，以及履行义务的管理和技术措施、能力等能否保障出境个人信息的安全；

（四）个人信息出境后遭到篡改、破坏、泄露、丢失、非法利用等的风险，个人信息权益维护的渠道是否通畅等；

（五）境外接收方所在国家或者地区的个人信息保护政策和法规对出境个人信息安全和个人信息权益的影响；

（六）其他可能影响个人信息出境安全的事项。
- #### 专业机构认证备案所需提交的材料
- 办理备案手续，应当提交下列材料。
- 1.取得个人信息保护领域认证资质等基本情况。包括个人信息出境认证专业机构备案申请表，以及认证机构批准书、统一社会信用代码证件、法定代表人身份证件、经办人身份证件影印件。

- 2.近三年从事数据安全和个人信息保护领域专业工作情况。主要包括参与数据安全和个人信息保护相关政策标准制定情况，开展数据安全认证、个人信息保护认证、数据安全风险评估、个人信息保护合规审计等工作情况。
- 3.人员安全背景审查材料。包括本机构对人员安全背景审查的说明，本机构所有从事个人信息出境认证工作的工作人员的背景审查表影印件。
- 4.个人信息保护认证实施细则。实施细则应依据《个人信息保护认证实施规则》制定，明确认证依据、认证模式、认证实施程序、认证证书和认证标志、认证责任等具体内容。
- 5.开展个人信息出境认证的工作计划。主要包括开展认证服务的基础条件、管理能力、技术能力、人力资源、场所与设备资源等方面。
- 6.个人信息安全风险防范机制说明。主要包括内部个人信息保护管理制度，对企业认证申请材料、档案、数据采取的安全保护措施，对认证服务中知悉的个人隐私、个人信息、商业秘密、保密商务信息的保密措施等。
- 7.对获证个人信息处理者进行的个人信息出境活动符合认证标准情况的持续监督机制说明。主要包括监督方式、频次、周期、有效性说明，以及对发现不再符合认证要求的个人信息出境活动的措施。
- 8.投诉受理和争议解决机制说明。从对个人信息出境活动的投诉、认证客户的投诉、与认证客户的争议等方面，对公开的投诉受理渠道、内部处理工作规范、实际执行情况等进行说明。
- 9.其他需要提交的证明材料。

我们在这个路径可以帮助企业完成：认证前的自检

路径三：个人信息出境标准合同备案

主要依据：《个人信息出境标准合同备案指南（第二版）》

适用条件

同时符合下列情形的应当向所在地省级网信部门备案：

- （一）关键信息基础设施运营者以外的数据处理者；
- （二）自当年1月1日起，累计向境外提供10万人以上、不满100万人个人信息（不含敏感个人信息）的；
- （三）自当年1月1日起，累计向境外提供不满1万人敏感个人信息的。

属于《促进和规范数据跨境流动规定》第三条、第四条、第五条、第六条规定情形的，从其规定。

个人信息处理者不得采取数量拆分等手段，将依法应当通过出境安全评估的个人信息通过订立标准合同的方式向境外提供。

办理途径

登录数据出境申报系统，网址：<https://sjcj.cac.gov.cn>。

逐步上传填写方式：

确定适用条件

个人信息出境标准合同备案

当前用户：个人信息处理者 | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

个人信息处理者通过订立标准合同的方式向境外提供个人信息的，应当同时符合下列情形

☐ （一）关键信息基础设施运营者以外的数据处理者；

☐ （二）自当年1月1日起，累计向境外提供10万人以上、不满100万人个人信息（不含敏感个人信息）的；

☐ （三）自当年1月1日起，累计向境外提供不满1万人敏感个人信息的；

个人信息处理者基本情况

— 个人信息出境标准合同备案 —

当前用户: 个人信息处理者 - [头像] | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

个人信息处理者基本情况

* 单位名称

单位性质

企业

请输入其他单位性质

* 单位类型

请选择单位类型

请输入其他单位类型

单位注册地

* 办公所在地

员工数量

员工数量单位

万人

统一社会信用代码

* 是否为关键信息基础设施运营者

* 处理个人信息规模

按自然人（去重）统计数量

* 处理个人信息规模单位

请选择单位

法定代表人信息

— 个人信息出境标准合同备案 —

当前用户: 个人信息处理者 - [头像] | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

法定代表人信息

☐ 无法定代表人

* 姓名

* 国籍

中国

* 联系电话

* 电子邮箱

* 证件类型

居民身份证

请输入其他证件类型

* 证件号码

* 职务

经办人信息

— 个人信息出境标准合同备案 —

当前用户: 个人信息处理者 - [头像] | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

经办人信息

* 姓名

* 国籍

朝鲜

* 联系电话

* 电子邮箱

* 证件类型

居民身份证

请输入其他证件类型

* 证件号码

* 职务

承诺书

— 个人信息出境标准合同备案 —

当前用户：个人信息处理者 · 陈桂洲 | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

承诺书

请上传《承诺书》签字并加盖公章的影印件

* 承诺书：

请上传格式为PDF、OFD、PNG、JPG、JPEG的文件

文件上传

《承诺书》模板下载

个人信息出境场景

— 个人信息出境标准合同备案 —

当前用户：个人信息处理者 · | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

个人信息出境场景1

* 出境场景描述

填写拟出境个人信息类型，比如姓名(真实姓名)、电话号码(手机号或固定电话号)、身份证(身份证号码或身份证照片)、护照(护照号码或护照照片)、电子邮箱、移动设备型号(如手机、PAD型号)、社交媒体账号、社交媒体浏览\搜索\点赞等行为记录、银行卡号、交易信息、用户设置的访问密码、设备型号信息、位置信息(静态信息)、轨迹信息(动态信息)、影像记录信息、个人生物识别信息(面部识别或指纹识别或声音识别)、病例、医疗影像信息、工作经历、教育经历信息、办公地址、家庭地址、家庭成员、家庭财产信息(如家庭收入、债务)、其他

拟出境数据情况

* 数据类型

个人信息

* 是否包含敏感个人信息

请选择是否包含敏感个人信息

* 涉及行业/领域

请选择涉及行业/领域

涉及其他行业/领域

请输入涉及行业/领域(其他)

* 涉及自然人(去重)数量

请输入涉及自然人(去重)数量

* 涉及自然人(去重)数量单位

请选择单位

个人信息出境标准合同

— 个人信息出境标准合同备案 —

当前用户：个人信息处理者 · | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

个人信息出境标准合同

* 标准合同订立日期

请选择标准合同订立日期

* 标准合同生效日期

请选择标准合同生效日期

相关商业合同名称

请输入相关商业合同名称

* 标准合同文件：

请上传格式为PDF、OFD、PNG、JPG、JPEG的文件

文件上传

请上传《个人信息出境标准合同》加盖公章的影印件

《个人信息出境标准合同》模板下载

个人信息出境标准合同模板：

个人信息出境标准合同

国家互联网信息办公室 制定

 个人信息出境标准合同【模板】.docx

个人信息保护影响评估报告（这是我们可以服务的环节）

— 个人信息出境标准合同备案 —

当前用户：个人信息处理者 | 退出

新建标准合同备案项目

个人信息出境标准合同备案

个人信息处理者基本情况

法定代表人信息

经办人信息

承诺书

个人信息出境场景

个人信息出境标准合同

个人信息保护影响评估报告

其他相关证明材料

适用情形

个人信息保护影响评估报告

请上传《个人信息保护影响评估报告》加盖公章的影印件

* 个人信息保护影响评估报告:

请上传格式为PDF、OFD、PNG、JPG、JPEG的文件

文件上传

《个人信息保护影响评估报告》模板下载

个人信息保护影响评估报告（模板）

个人信息保护影响评估报告（模板） （出境版）

个人信息处理者名称：_____（盖章）

年 月 日

2. 欧盟框架

荷兰学者Joost Gerritsen画了十张图阐释GDPR下数据跨境传输的含义和范围，内容来源是EDPB发布第3条与第V章关系的指南，前两天最终版本公布。



Example 1: Controller in a third country collects data directly from a data subject in the EU (under Article 3(2) GDPR)

Maria, living in Italy, inserts her name, surname and postal address by filling a form on an online clothing website in order to complete her order and receive the dress she bought online at her residence in Rome. The online clothing website is operated by a third country company that has no presence in the EU, but specifically targets the EU market. In this case, the data subject (Maria) passes her personal data to the third country company. This does not constitute a transfer of personal data since the data are not passed by an exporter (controller or processor), but directly collected from the data subject by the controller under Article 3(2) GDPR. Thus, Chapter V does not apply to this case. Nevertheless, the third country company will be required to apply the GDPR since its processing operations are subject to Article 3(2).



Example 2: Controller in a third country collects data directly from a data subject in the EU (under Article 3(2) GDPR) and uses a processor outside the EU for some processing activities

Maria, living in Italy, inserts her name, surname and postal address by filling a form on an online clothing website in order to complete her order and receive the dress she bought online at her residence in Rome. The online clothing website is operated by a third country company that has no presence in the EU, but specifically targets the EU market. In order to process the orders received by means of the website, the third country company has engaged a non-EEA processor. In this case, the data subject (Maria) passes her personal data to the third country company and this does not constitute a transfer of personal data since the data are directly collected by the controller under Article 3(2) GDPR. Thus, the controller will have to apply the GDPR to the processing of this personal data. As far as it engages a non-EEA processor, such disclosure from the third country company to its non-EEA processor would amount to a transfer, and it will be required to apply Article 28 and Chapter V obligations so as to ensure that the level of protection afforded by the GDPR would not be undermined when data are processed on its behalf by the non-EEA-processor.

[2016年通过的欧盟数据保护立法改革](#)提供了向第三国传输数据的多元化机制工具包：[充分性决定](#)、[标准合同条款](#)、[具有约束力的公司规则](#)、认证机制、行为准则、所谓的“[减损](#)”等。

朱悦，《[【域外】不具备充分性的数据跨境传输](#)》

2.1充分性决定

第45条 基于认定具有充足保护的转移

- 1. 当欧盟委员会作出认定，认为相关的第三国、第三国中的某区域或一个或多个特定部门、或国际组织具有充足保护，可以将个人数据转移到第三国或国际组织。此类转移不需要特定的授权。
- 2. 当评估保护程度的充足性时，欧盟委员会应当特别考虑如下因素：
 - (a)法治、对人权与基本自由的尊重、包括关于公共安全、国防、国家安全、刑法和公共机构访问个人数据的一般性与部门性立法，以及此类立法的实施、数据保护规则、职业规则和安全措施，包括将个人数据转移到另一第三国或国际组织所必须遵循的第三国或国际组织的规则、判例法以及有效可执行的数据主体权利、对其个人数据正在转移的数据主体的司法救济；
 - (b)在国际组织是主体的情形中，第三国内存在一个或多个有效运作的独立监管机构，保证数据保护规则的实施，包括具有充分的执行权力，在数据主体行使其权利时和与成员国的监管机构合作时提供帮助和建议；
 - (c)第三国或国际组织已经许下的国际性承诺，或者承诺愿意承担有法律约束力的条约或法律文件所引起的其它责任，以及参加多边或地区性的体系，特别是和数据保护相关的体系所引起的其它责任。
- 3. 在评估了保护程度的充足性之后，欧盟委员会可以通过制定实施性法案，确定本条第2段含义内的第三国、第三国内的领地或一个或多个特定部门或一个国际组织是否具有充足的保护。实施性法案应当提供一种周期性审查，至少每四年对第三国或国际组织的所有相关发展进行审查。实施性法案应当细化其领域性与部门性的实施，以及在适用的情况下确定本条第2段（b）点所规定的一个或多个监管机构。实施性法案的制定应当遵循第93（2）条所规定的验证程序。
- 4. 欧盟委员会应当持续性地监控第三国或国际组织的某些可能会影响根据本条第3款而作出的决定和建立在95/46/EC指令第25（6）条基础之上的决定发挥作用的某些发展。
- 5. 当已有信息显示，第三国或第三国内的一个或多个特殊部门或国际组织不再提供本条第2段所规定的充足的保护，欧盟委员会应当——尤其是在经过第3段所规定的核查后——通过制定不具有溯及力的实施性法案，在必要限度内废止、修正或中止本条第3段所规定的决定。此类实施性法案的制定应当遵循第93（2）条所规定的验证程序。
在具有高度正当性的紧急状态情形中，欧盟委员会应当立即根据第93（3）条规定的程序而制定实施性法案。
- 6. 为了补救导致第5条决定的情形，欧盟委员会应当与第三国或国际组织磋商。
- 7. 符合本条第5段的决定不会影响到将个人数据转移到第三国、第三国内的领地或一个或多个部门、或者第46条至49条所规定的相关国际组织。
- 8. 欧盟委员会应当在欧盟的官方杂志及其网站上发表名单，列明其确定已经具备充足保护或不再具有充足保护的第三国、第三国内的特定部门和国际组织。
- 9. 欧盟委员会在95/46/EC指令第25（6）条基础上而做出的决定，在被欧盟委员会根据本条第3段或第5段而修改、替代或废止前应具有效力。

- a. 2019年，欧盟和日本承认彼此的数据保护系统是“等同的”，从而允许个人数据在欧盟和日本之间自由流动。这种安排创造了世界上最大的自由和安全数据流区域。
- b. 2023年6月，欧盟通过了对英国和韩国的充分性决定。2023年7月，欧盟委员会通过了“欧盟-美国数据隐私框架”的充分性决定。
- c. 2023年4月，欧盟委员会通过一份报告，结束了对日本的首次审查，欧盟委员会还对英国和美国的数据保护执行情况进行监督。
- d. 欧盟委员目前共有16项充分性决定，分别针对[安道尔](#)、[阿根廷](#)、[加拿大（根据PIPEDA）](#)、[法罗群岛](#)、[根西岛](#)、[以色列](#)、[马恩岛](#)、[日本](#)、[泽西岛](#)、[新西兰](#)、[大韩民国](#)、[瑞士](#)、[英国（根据GDPR和LED）](#)、[美国（根据欧盟-美国数据隐私框架认证的商业组织）](#)和[乌拉圭](#)

定期审查：

委员会需要定期审查根据 GDPR 及其前身 95/46/EC 指令通过的充分性决定，并向欧洲议会和理事会报告其调查结果。

- a. 委员会于 2023 年 4 月 4 日发布了关于[日本充分性决定的第一次定期审查的报告](#)。
- b. 2024 年 1 月 15 日，委员会发布了[关于根据《日本充分性决定》通过的 11 项充分性决定的运作情况的第一次审查报告。符合指令 95/46/EC。](#)

2.2标准合同（是我们能做的）

欧盟的标准合同条款（SCC）有：

- 2010年出台了基于95指令的标准合同，目前已失效；
- 2021年欧盟委员会制定了新的标准合同条款，链接如下：https://ec.europa.eu/info/law/law-topic/data-protection/international-dimension-data-protection/standard-contractual-clauses-scc/standard-contractual-clauses-international-transfers_en
 - 欧盟/欧洲经济区**数据控制者和处理者的标准合同条款**
 - 欧盟/欧洲经济区以外**个人数据传输的标准合同条款**
 - 欧盟C2C模式SCC，可编辑的中英双语word（感谢吴智婉律师的贡献）：

☐ Q&A: [New Standard Contractual Clauses - Questions and Answers overview](#)

a. 标准合同条款的文本可以更改吗？

除以下情况外，标准合同条款的文本不得更改：(i) **选择文本中提供的模块和/或特定选项**；(ii) 根据需要**补充文本**（以方括号标示），例如指明主管法院和监管机构，以及明确时间段；(iii) **填写附件**；或 (iv) 添加可提高数据保护级别的**额外保障措施**。这些调整不视为对核心文本的更改。

关于控制者和处理者的标准合同条款的具体信息： 如果双方更改标准合同条款的文本（除下文提到的调整外），则他们不能依赖欧盟法律提供的法律确定性。

b. 各方能否删除不适用于自身情况的模块和/或选项？

在使用标准合同条款时，双方应仅约定与自身情况相关的条款。不适用的模块和/或选项应予以删除。

例如： 数据控制者希望将个人数据传输给另一个数据控制者，并依赖标准合同条款（SCC）进行国际数据传输。应提取所有未指明模块的通用条款（例如，第一部分）以及与标准合同条款模块 1 相关的条款。所有仅与其他模块相关的条款均可删除。

解读：

参见陈际红，《[欧盟个人数据传输的两项新工具（SCCs）：历史演变、法律影响和应对策略](#)》

中国与欧盟的比较：参见邦信阳中建中汇，《[个人信息出境标准合同中的“共性”与“个性” ----基于域外实践的横向比较观察](#)》。

2.3 BCR（是我们能做的）

第47条 有约束力的公司规则

1. 在满足如下条件时，对于符合第63条所规定的一致性机制的有约束力的公司规则，有权监管机关应当批准：
 - (a)具有法律约束力，适用于进行联合经济活动的企业集团或一系列经济主体的所有相关成员——包括其雇员，并且为他们所执行。
 - (b)在处理个人数据方面明确赋予数据主体以可执行的权利；以及
 - (c)满足第2段所规定的要求。
2. 第1段所规定的有约束力的规则应当至少明确：
 - (a)进行联合经济活动的企业集团或一系列经济主体，及其每一个成员的架构和详细联系方式；
 - (b)数据转移或一系列的数据转移，包括个人数据的类型；处理类型及其目的；受影响的数据主体的类型；以及涉及到的对第三国或多个第三国的确定；
 - (c)规则的法律约束效力，既包括内部的约束力，也包括外部的约束力；
 - (d)对一般数据保护原则的适用，特别是目的限定、数据最小化、有限的储存期限、数据质量、通过设计的数据保护与默认的数据保护、处理的法律基础、对特定类型个人数据的处理；保障数据安全的措施；以及将数据转移到不受约束性公司规则所约束的实体所做的要求；
 - (e)和处理相关的数据主体的权利以及行使这些权利的方式，包括有权不被仅仅根据自动化处理——包括符合第22条的用户画像——而对数据主体做出决定，有权按照第79条向有权监管机构和成员国的有权管辖的法庭申诉，以及有权在违反有约束力的公司规则的情形下获取救济和——如果适用的话——赔偿；
 - (f)对于任何不在欧盟设立的控制者或处理者的相关成员违反约束性公司规则，在成员国的领域内设立的控制者或处理者愿意承担责任；只有当控制者或处理者证明，该成员对于导致损害的事件没有责任，控制者或处理者的此种责任才能被免除；
 - (g)关于约束性公司规则的信息如何提供给数据主体，特别是第13和14条之外关于本段所规定的(d)(e)(f)点的信息如何提供给数据主体；

- (h)根据第37条所委任的所有数据保护官的任务，或者企业集团、或进行联合经济活动的一系列经济主体内部负责监控遵守约束性公司规则、监控培训和处置申诉的所有人或实体的任务；
- (i)申诉程序；
- (j)企业集团或进行联合经济活动的一系列经济主体，为了核实对约束性公司规则的遵守的而在内部所设立机制。此类机制应当包括数据保护核查以及能够确保采取矫正性活动保护数据主体权利的方法。此类核实结果应当告知（h）点所规定的个人或实体，企业集团或进行联合经济活动的一系列经济主体，而且在有权监管机构的要求下应当能够提供其核实结果；
- (k)报告和记录规则变化的机制，以及将此类变化报告给监管机构的机制；
- (l)为了保证企业集团或进行联合经济活动的一系列经济主体的合规性而和监管机构一起设立的合作机制，特别是向监管机构提供（j）点所规定的方法的核查结果；
- (m)企业集团或进行联合经济活动的一系列经济主体的成员是第三国的主体，可能会对约束性企业规则所提供的保障产生实质性的负面影响，向有权监管机构报告对此类主体是否有法律要求的机制；以及
- (n)对于可永久性或经常性访问个人数据的员工进行的适当数据保护培训。
3. 欧盟委员会可以明确控制者、处理者和监管机构之间为了本条含义内的约束性公司规则而进行信息交换的形式和程序。此类实施性法案的制定应当遵循第93（2）条所规定的验证程序。

What are binding corporate rules?

Binding corporate rules (BCR) are data protection policies adhered to by companies established in the EU for transfers of personal data outside the EU within a group of undertakings or enterprises. Such rules must include all general data protection principles and enforceable rights to ensure appropriate safeguards for data transfers. They must be legally binding and enforced by every member concerned of the group.

Approval of binding corporate rules

Companies must submit binding corporate rules for approval to the competent data protection authority in the EU. The authority will approve the BCRs in accordance with the consistency mechanism set out in Article 63 of the [GDPR](#). This procedure may involve several supervisory authorities since the group applying for approval of its BCRs may have entities in more than one Member State. The competent authority communicates its draft decision to the European Data Protection Board, which will issue its opinion on the binding corporate rules. When the BCRs have been finalised in accordance with the EDPB opinion, the competent authority will approve the BCRs.

Recommendations



Recommendations 1/2022 on the Application for Approval and on the elements and principles to be found in Controller Binding Corporate Rules (Art. 47 GDPR)

Adopted on 20 June 2023

Adopted

1

第49条 特殊情形下的克减

1. 如果不存在根据第45（3）而做出的充足保护认定或根据第46条而制定的适当安全措施——包括约束性公司规则，将个人数据转移到第三国或国际机构，只有满足如下情形之一才能进行：
- (a)数据主体被明确告知，不存在充足保护或适当的安全措施，预期的数据转移存在风险，但之后数据主体仍然明确表示同意预期的数据转移；
- (b)转移对于履行数据主体与控制者之间的合同，或者履行数据主体在签订契约前所提出要求是必要的；
- (c)控制者和另一自然人或法人之间签订或履行合同时，转移对于实现数据主体的利益是必要的；
- (d)转移对于实现公共利益是必要的；
- (e)转移对于确立、行使或辩护法律性主张是必要的；
- (f)当数据主体基于身体性或法律性原因无法表达同意，为了保护数据主体或其他人的关键利益是必要的；
- (g)转移是根据登记册而进行的——这种登记册是欧盟法或成员国法律为了向具有正当利益的一般性公众或个人提供咨询。但是，只有满足欧盟法或成员国法对咨询所规定必要条件，此类个案中的转移才能进行克减。
- 当转移无法基于第45或第46条，包括基于约束性公司规则的条款的规定而进行，且从（a）点到（g）的克减条件都不符合，将数据转移到第三国或国际组织，这只有在转移满足如下条件时才可以：转移是非重复性的；关乎很小一部分数据主体的权利；对于实现控制者压倒性的正当利益是必要的，并且不会违反数据主体的有限性的利益或权利与自由；控制者已经对围绕数据传输的情形进行评估，而且基于这种评估对个人数据保护采取了合适的安全保障。控制者除了提供第13条和第14条所规定的信息之外，应当将转移和追求的压倒性正当利益告知数据主体。
2. 符合第1段（g）点的转移不应当包括登记册里的全部个人数据或所有类型的个人数据。当登记册是为了给具有正当利益的人提供咨询的，只有那些人提出要求，或者那些人是接收者的情形才能进行转移。
3. 对于公共机构在行使其公共权力时的活动，第1段的（a）（b）（c）点以及第1段的第二分段不适用。
4. 第1段（d）点规定的公共利益应当为欧盟或成员国为控制者所制定的法律所确认。
5. 如果不存在充足保护的认定，欧盟或成员国的法律可以基于公共利益而明确做出限制，限制将个人数据转移到第三国或国际组织的特定类型。成员国应当将此类条款告知欧盟委员会。
6. 控制者或处理者应当在第30条规定的档案中记录本条第1段第二分段所规定的评估以及合适的安全措施。

[Guidelines 2/2018 on derogations of Article 49 under Regulation 2016/679](#)；[网路西东翻译版本](#)  [关于根据第2016679号条例第49条“克减”的 22018号指南.pdf](#)

适用时同样需要确保 GDPR 保障的自然人保护水平不受损害。—— 这意味着也需要进行TIA。

必要性测试 Necessity Test

这是适用的首要条件，数据传输必须是为了某种目的且“必要”。

应当采用必要性测试来评估是否可能使用第 49 条第(1)款(b)(c)(d)(e)(f)项的克减。

“偶尔” 传输

第 49 条第(1)款(b)(c)(e)项 —— 仅限于“偶尔” 传输。



偶尔传输：这种传输可能不止一次发生，但不是经常发生，而且会在正常行动过程之外发生，例如，在随机、未知的情况下，在任意的时间间隔内发生。

例如，在数据输出者和某个数据输入者之间的稳定关系中定期发生的数据传输基本上可以被视为是系统的和重复的，因此不能被认为是偶然的或非重复的。此外，例如，当数据输入者基于一般法律被授予直接访问数据库的权限(例如，通过 IT 适用程序的接口)时，通常会认为传输是非偶然的或重复的。

条款	适用场景	条件
49.1 (a)	同意	
49.1 (b)	履行合同所必需	必要性测试 偶尔的传输
49.1 (c)	控制者和另一自然人或法人之间签订或履行合	必要性测试 偶尔的传输

	同时，传输对于实现数据主体的利益是必要的	
49.1 (d)	重大公共利益克减	必要性测试 根据第 49 条第 (4) 款，只有欧盟法规或控制者所属成员国法律承认的公共利益才能导致适用该克减。
49.1 (e)	为确立、行使或辩护法律主张而必要	必要性测试 偶尔的传输
49.1 (f)	数据主体在生理上或法律上无法给予同意时，为保护数据主体或其他人的重大利益	
49.1 (g) 和 49.2	从公共登记册进行的传输	
49.1第2段	compelling legitimate interests	只适用于“传输不能基于第 45 条或第 46条的规定，包括关于具有约束力的公司规则的规定，且对特定情况的克减均不适用”的情况 非重复的传输； 传输必须只涉及有限数量的数据主体； 通知监管机构； 告知数据主体

2.5 DPIA（我们可以做）

Article 35 of GDPR

Data protection impact assessment

1. Where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data. A single assessment may address a set of similar processing operations that present similar high risks.
2. The controller shall seek the advice of the data protection officer, where designated, when carrying out a data protection impact assessment.
3. A data protection impact assessment referred to in paragraph 1 shall in particular be required in the case of:

(a) a systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person;

(b) processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10; or

- 1.当一种处理行为特别是用到了新技术时，考虑到处理行为的性质、范围、内容和目的可能会对自然人的权利和自由产生高风险时，数据控制者应当在处理前完成一份设想的数据处理对个人数据保护影响的评估。一份评估可以解决存在相似高风险的一套类似的处理行为。
- 2.数据控制者在实施数据保护影响评估时，在指定的情形下应当征询DPO的建议。
- 3.在以下情形中尤其需要第 1 款规定的数据保护影响评估：**

(a) 基于数据的自动化处理包括识别分析（profiling），或者基于对该自然人产生法律效力或者类似的显著影响的决定，对自然人个人方面的系统和广泛的评估；

(b) 处理大规模的第 9 条第 1 款规定的特殊类型的数据，或大规模的第 10条规定的有关犯罪记录和违法行为的个人数据；或者

(c) 对公共区域大规模的系统化监控。
- 4.监管机构应当确定并公开一份清单，列举应当按照第 1 款规定进行数据保护影响评估的处理

(c) a systematic monitoring of a publicly accessible area on a large scale.

4. The supervisory authority shall establish and make public a list of the kind of processing operations which are subject to the requirement for a data protection impact assessment pursuant to paragraph 1. The supervisory authority shall communicate those lists to the Board referred to in Article 68.

5. The supervisory authority may also establish and make public a list of the kind of processing operations for which no data protection impact assessment is required. The supervisory authority shall communicate those lists to the Board.

6. Prior to the adoption of the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism referred to in Article 63 where such lists involve processing activities which are related to the offering of goods or services to data subjects or to the monitoring of their behaviour in several Member States, or may substantially affect the free movement of personal data within the Union.

7. The assessment shall contain at least:

(a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller;

(b) an assessment of the necessity and proportionality of the processing operations in relation to the purposes;

(c) an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1; and

(d) the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Regulation taking into account the rights and legitimate interests of data subjects and other persons concerned.

8. Compliance with approved codes of conduct referred to in Article 40 by the relevant controllers or processors shall be taken into due account in assessing the impact of the processing operations performed by such controllers or processors, in particular for the purposes of a data protection impact assessment.

9. Where appropriate, the controller shall seek the views of data subjects or their representatives on the intended processing, without prejudice to the protection of commercial or public interests or the security of processing operations.

10. Where processing pursuant to point (c) or (e) of Article 6(1) has a legal basis in Union law or in the law of the Member State to which the controller is subject, that law regulates the specific processing operation or set of operations in question, and a data protection impact assessment has already been carried out as part of a general impact assessment in the context of the adoption of that legal basis, paragraphs 1 to 7 shall not apply unless Member States deem it to be necessary to carry out such an assessment prior to processing activities.

行为。监管机构应当将清单告知第 68 条规定的欧洲数据保护委员会。

5.监管机构同样要确定并公开一份清单，列举不需要进行数据保护影响评估的处理行为。监管机构也应将该清单告知欧洲数据保护委员会。

6.在采用第 4 款和第 5 款规定的清单前，若清单涉及向数据主体提供商品或服务的处理行为，或在多个成员国监控他们的行为的处理行为，或可能对个人数据在欧盟境内的自由流通产生实质影响的处理行为，监管机构应当适用第 63 条规定的一致性机制。

7.评估内容至少应当包括如下方面：

(a) 对于设想中的处理行为和处理行为的目的系统化的说明，适当的情况下还包括控制者追求的合法利益；

(b) 基于处理目的，对处理行为的必要性和相称性的评估；

(c) 对于第 1 款中规定的对数据主体权利和自由产生的风险的评估；

(d) 处理这些风险的预想方案，包括安全保障措施，以及确保个人数据的保护和证明符合本条例规定的机制。以上方案应当考虑数据主体和其他相关人员的权利和合法利益。

8.在对数据控制者或处理者进行的处理行为进行影响评估时，尤其是为了达到数据保护影响评估的目的，应当考虑该数据控制者或处理者对第 40 条规定的行为准则的遵守情况。

9.在适当的情况下，数据控制者应当就打算的处理行为征询数据主体或其代表人的意见，但不应影响商业或公共利益的保护，以及处理活动的安全保障。

10.依据第 6 条第 1 款 (c) 项和 (e) 项进行的处理行为在数据控制者所遵守的欧盟或成员国法律中具有法律依据，这些法律规定了某一具体处理行为或者一系列处理行为，并且在适用上述法律依据时已经实施了一项作为一般影响评估一部分的数据保护影响评估，该种情况下不适用本条第 1 到 7 款的规定，除非成员国认为在处理活动前实施数据保护影响评估是有必要的。

11.必要的时候，至少是当处理行为出现风险变化的时候，数据控制者应当进行复审以评估数

11. Where necessary, the controller shall carry out a review to assess if processing is performed in accordance with the data protection impact assessment at least when there is a change of the risk represented by processing operations. 据处理行为是否符合数据保护影响评估。

(recital 71.75.91) (WP29指南从严解释)

- (1) 评估或评分（包括分析预测），e.g., 金融公司利用反欺诈、反洗钱数据库筛选客户；生物技术公司预测疾病；建立营销档案
- (2) 自动化决策=Art.22情形
- (3) 处理特殊类型数据（Art.9）或犯罪数据（Art.10）,e.g. 医院保留就诊记录
- (4) 对公共区域（e.g., 广场、购物中心、街道、火车站）系统化监控
- (5) 大规模处理，考虑数据主体数量/占比、数据量、处理持续时间、地域范围
- ✓ 医院在正常业务过程中对病人数据的处理
 - ✓ 处理城市公共交通系统的个人数据（例如，通过旅行卡的追踪）
 - ✓ 国际快餐连锁店为统计目的对顾客的实时地理定位数据进行处理
 - ✓ 专业统计公司的数据处理
 - ✓ 保险公司或银行在正常业务过程中对客户数据的处理
 - ✓ 搜索引擎为行为广告处理个人数据
 - ✓ 电话或互联网服务提供商对数据（内容、流量、位置）的处理
 - ✗ 个人医生（e.g.,小诊所）对病人数据的处理
 - ✗ 个人律师处理与刑事定罪和犯罪有关的个人数据
- (6) 组合或匹配数据集，超出数据主体合理预期
- (7) 数据涉脆弱主体，e.g., 儿童、雇员、病患、老人
- (8) 使用新技术，e.g., AI
- (9) 处理活动本身阻止数据主体行使权利或使用服务/合同时，e.g., 银行根据信用参考数据库筛选其客户，以决定是否向他们提供贷款
- ISO/IEC 29134:2017《隐私影响评估指南》  [1. ISO 29134.pdf](#)
 - 英国ICO的DPIA
 -  [2.1 ICO_DPIA_brief and detailed guidance for DPIA.pdf](#)

Sample DPIA template

This template is an example of how you can record your DPIA process and outcome. It follows the process set out in our DPIA guidance, and should be read alongside that guidance and the [Criteria for an acceptable DPIA](#) set out in European guidelines on DPIAs.

You should start to fill out the template at the start of any major project involving the use of personal data, or if you are making a significant change to an existing process. The final outcomes should be integrated back into your project plan.

Submitting controller details

Name of controller	
Subject/title of DPO	
Name of controller contact /DPO (delete as appropriate)	

Sample DPIA template

This template is an example of how you can record your DPIA process and outcome. It follows the process set out in our DPIA guidance, and should be read alongside that guidance and the [Criteria for an acceptable DPIA](#) set out in European guidelines on DPIAs.

You should start to fill out the template at the start of any major project involving the use of personal data, or if you are making a significant change to an existing process. The final outcomes should be integrated back into your project plan.

Step 1: Identify the need for a DPIA

Explain broadly what project aims to achieve and what type of processing it involves. You may find it helpful to refer or link to other documents, such as a project proposal. Summarise why you identified the need for a DPIA.

依赖GDPR第46.2条和第46.3条所列传输工具（如标准合同条款（SCCs）、约束性公司规则（BCR））进行数据传输的出口商，有义务评估目的地第三国的保护水平及是否需要额外保障措施。此类评估通常被称为“数据传输影响评估（TIA）”。

真正的义务方是数据出口方（也就是传数据的那一方），它可能是控制者，也可能是处理者，甚至可能是子处理者。而数据进口方（收数据的那边）得帮忙配合，比如提供他们国家的法律和执法情况。

指南：

a. European Data Protection Board：

- i. [Guidelines 05/2021 on the Interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR](#)
- ii. [Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data](#)

b. 法国CNIL发布了《数据传输影响评估（TIA）指南》：https://cnil.fr/sites/default/files/2025-07/guide_tia.pdf

参考模板：

目前，欧盟没有发布TIA评估的模板，由控制者自行设计评估问卷。

TRANSFER IMPACT ASSESSMENT

Based on Transfer Impact Assessment, Draft guide for public consultation until 12 February 2024, published by CNIL, France.

Step 1 – Know Your Transfer

In order to ensure an essentially equivalent level of protection for the data transferred, wherever it is being processed, first it is necessary to describe the transfer.

To complete the table below, you can use your pre-existing internal documentation, such as the record of processing activities or the contract governing the transfer. You can also contact the data importer.

Step 1: Know Your Transfer	
Exporter Name	
Contact Point and Contact Details	
Exportation Country	
Exporter Qualification in the Context of the Data Transfer	☐ Controller ☐ Joint Controller ☐ Processor <i>If "Processor" or "Joint Controller", provide the name of the Controller:</i>
Importer Name	
Contact Point and Contact Details	
Importation Country	
Importer Qualification in the Context of the Data Transfer	☐ Controller ☐ Joint Controller ☐ Processor <i>If "Processor" or "Joint Controller", provide the name of the Controller:</i>
Nature of the Data Importer's Activities	☐ Commercial ☐ Public sector ☐ Non-profit ☐ Other <i>If "Other", specify:</i>
Transfer Start Date	
Intended Transfer End Date or Transfer Duration	
Transfer Purpose(s) and Processing Activities Undertaken by the Importer Regarding the Transferred Data (e.g. IT support, marketing, provision of cloud software, data hosting)	

 TIA - Template.docx

对第三国法律制度的评价：

评估标准：European Essential Guarantees（简称EGG）

依据：[Recommendations 02/2020 on the European Essential Guarantees for surveillance measures](#)

EGG一共有四个部分：

3. THE EUROPEAN ESSENTIAL GUARANTEES.....	8
Guarantee A - Processing should be based on clear, precise and accessible rules.....	8
Guarantee B - Necessity and proportionality with regard to the legitimate objectives pursued need to be demonstrated	10
Guarantee C - Independent oversight mechanism.....	12
Guarantee D - Effective remedies need to be available to the individual	13

此外，EDPB还会定期委托开展法律研究，协助监管机构评估某一第三国的法律是否允许对数据进行“广泛或不加区分的”访问。该等研究仅供参考，并不代表EDPB的官方立场，但对于企业开展数据跨境传输影响评估（Transfer Impact Assessment，简称TIA）具有重要参考价值。其中DPC在TikTok案中就参考了相关报告（Milieu Report）。

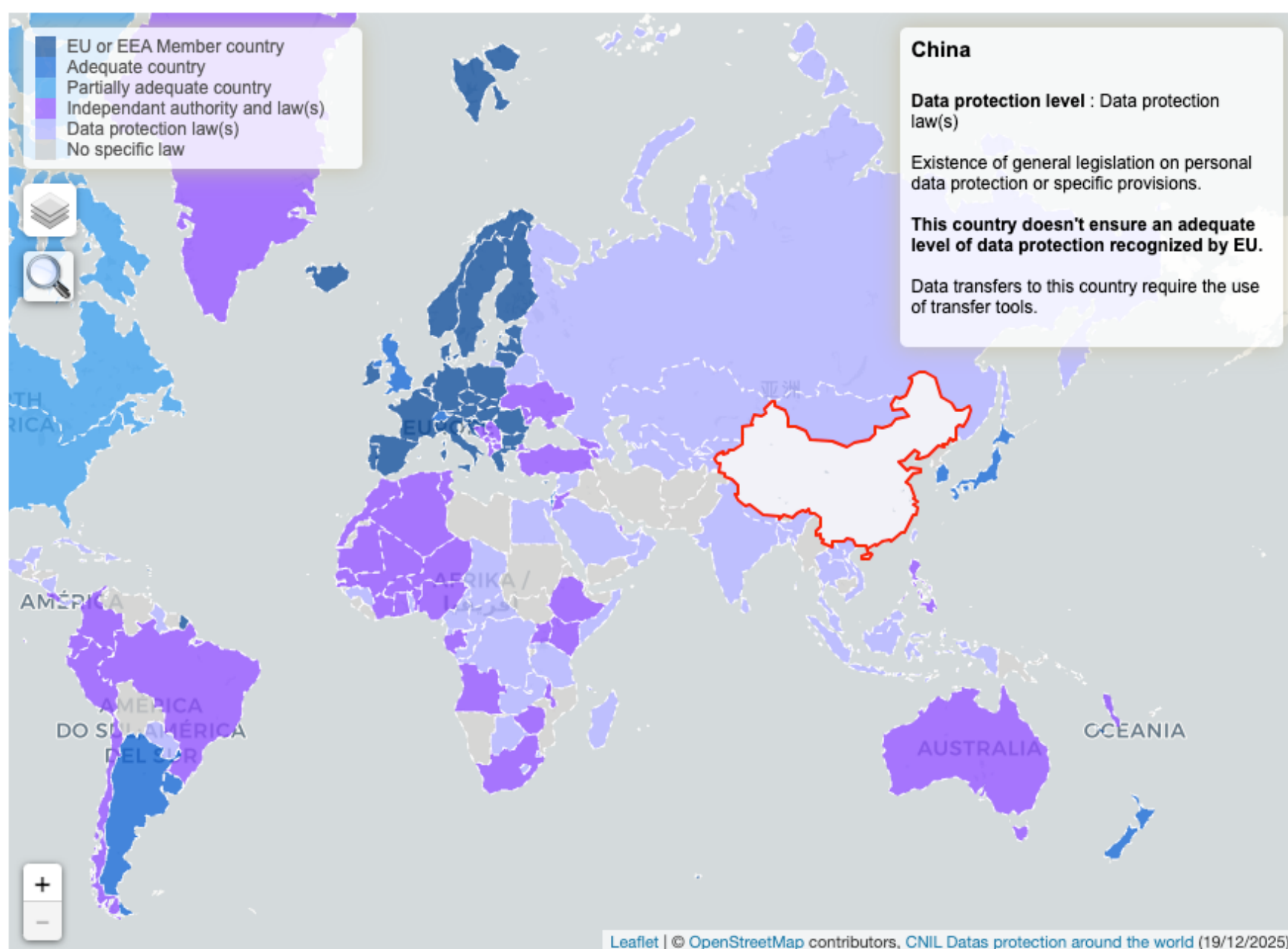
Milieu 报告是由鲁汶大学信息技术与知识产权法中心的研究人员在 Milieu Consulting 支持下开展的一项关于第三国（包括中国）政府数据获取的法律研究。

- 墨西哥&土耳其： [Legal study on government access to data in third countries - Mexico and Turkey](#)
- 巴西： [Legal study on government access to data in third countries - Brazil](#)
- 中国、印度&俄罗斯： [Legal study on government access to data in third countries - China, India, Russia](#)

法国CNIL提供了对于第三国的初步评估： <https://www.cnil.fr/en/data-protection-around-the-world>

This map allows you to see the level of data protection in each country. You may access the geo-position of all Data Protection Authorities by clicking on the « layer » icon, located on the left top side of the map.

The « magnifying » icon allows you to search a country on the map.



对于部分国家评估的参考

a. 新加坡：

- i. Scoot航空（2024）：https://cdn.flyscoot.com/prod/docs/default-source/gdpr-tia-feb-2024/tia---singapore---scoot-x-sales-agent_13dec23.pdf?sfvrsn=9a1747b1_1/TIA---SINGAPORE---Scoot-x-sales-agent_13Dec23.pdf
- ii. Google（2024）：用量化的方式去做的TIA（包括澳大利亚、智利、巴西、中国香港等）
<https://slmmicrosoftrijk.nl/wp-content/uploads/2024/07/Updated-DTIA-Google-Meet-for-NL-gov.pdf>

其他资料：

- 国际数据河龟酱，《数据跨境传输影响评估（TIA）怎么做？》
- 数据何规，《法国CNIL发布数据跨境TIA实践指南》

2.7 ROPA（略）

3.美国框架

特点一：立法零散：与中国和欧盟用专门的法律或其他规范规定数据跨境流通的做法不同，美国数据跨境流动管理的相关法律十分零散，目前没有任何生效的法律从联邦层面专门规定数据跨境流通，而是通过各种政策文件、政府间的协定来进行规范。

特点二：区别对待：美国主张数据跨境自由流动，特别是与其盟友及其发挥主导作用的国际联盟中，美国牵头提出了相关的倡议。但是，美国对中国却严加防范，不仅制定政策法规、提出议案严格限制，还肆意对抖音海外版（TikTok）等中国科技企业及产品严格审查质询，体现出其明显的“双重标准”。

特点三：数据跨境流通政治化：美国的立法和政策很在乎一点——美国政府机构能不能出于国家安全、情报、政治等考量，收集企业的数据。

3.1美—欧框架：

2022年3月，美国与欧盟之间达成《跨大西洋数据隐私框架》（Trans-Atlantic Data Privacy Framework）。一是在法律层面，美国同意设立数据保护审查法庭（Data Protection Review Court, DPRC），该法庭可以针对美国情报机构的数据收集进行取证。在监管方面，设立独立检察官，负责数据保护检查工作。欧盟公民可对数据保护相关问题在法庭进行投诉，法庭可以针对诉讼到美国情报机构进行取证。二是在美国情报机构内部设立数据保护机制，包括数据分类分级、限制数据收集范围、设立护栏等。美国公司的隐私和数据保护条款的法律将得到欧盟承认，美国情报机构只需遵循流程即可获取欧盟公民数据信息。

2022年10月，美国发布《关于加强美国信号情报活动保障措施的行政命令》（Executive Order on Enhancing Safeguards for United States Signals Intelligence Activities, EO14086）。十二项目“合法目标”中的第九项为“保护美国或其盟国或伙伴的人员免受威胁”。此外，该行政令还增加补救机制，以审查由符合条件的国家适当公共机构转交的有关美国信号情报活动的任何违反美国法律的合格投诉，并在必要时采取适当补救措施。在第一级救济机制不接受美国国家情报总监办公室（Office of the Director of National Intelligence, ODNI）的公民自由保护官（Civil Liberty Protection Officer, CLPO）的审查结果时，可以向美国司法部（United States Department of Justice）新成立的“数据保护审查法庭”对CLPO提起上诉；2023年7月，DNI发布“实施行政命令（前述）的新保障措施”；欧盟委员会则发布了《欧盟—美国数据隐私框架》（EU-U.S. Data Privacy Framework, DPF）的充分性决定，DPF恢复了个人数据跨境转移的重要机制，并对美国监控机构在“必要和适当”范围之外获取欧盟数据的行为进行了限制，建立了独立的争议解决机制，实现欧美之间安全可靠的数据流动。

3.2美—中框架

2018年3月，美国出台《澄清境外合法使用数据法案》（Clarifying Lawful Overseas Use of Data Act, CLOUD Act）对美国1986年的《电子通信隐私法》（Electronic Communications Privacy Act, ECPA）进行修订，主要更新内容为要求受美国管辖的网络服务提供商披露相关数据，响应美国法律程序，无论公司将数据存储在何处。该法案出台的直接原因是2017年末至2018年初，苹果将中国用户的云服务转由云上贵州运营，用户的个人信息（如联系人、照片、文件、应用程序数据等）将自动发送给云上贵州并存储。该法案则为了解决如果美国政府要求苹果公司将中国内地用户储存在 iCloud 中的数据提供给美国政府，苹果是否需要配合的问题。

 [cloud_act.pdf](#)

2021年1月，时任美国特朗普政府在下台前发布的《针对中国公司开发或控制的应用程序和其他软件构成的威胁的行政命令》（Executive Order Addressing the Threat Posed By Applications and Other Software Developed or Controlled By Chinese Companies）明确指出，通过访问智能手机、平板电脑和计算机，中国相关的软件应用可以访问和截取来自用户的大量信息，其中包括敏感个人识别信息和私人信息。这种信息收集“有可能让中国可以访问美国的个人和专有信息，进而使得中国能够追踪联邦雇员和承包商的位置，并构建个人信息档案”。这就算是作出了一个警告。

2021年6月，美国拜登政府在上台后不久发布《保护美国人敏感数据免受外国对手侵害的行政命令》（Executive Order on Protecting Americans’ Sensitive Data from Foreign Adversaries），指出导致美国面临数据安全的持续紧急状态最重要的因素是“外国对手（中国）”不断窃取或以其他方式获取美国人的数据。为了应对这一“威胁”，美国必须采取行动，防范与由外国对手拥有或控制、受外国对手管辖或指导的人员设计、开发、制造或提供的互联软件应用程序相关的风险。

2022年9月，美国发布《关于确保美国外国投资委员会（CFIUS）充分考虑不断变化的国家安全风险的行政命令》（Executive Order on Ensuring Robust Consideration of Evolving National Security Risks by the Committee on Foreign Investment in the United States），指出外国政府（中国等）获取某些类型的数据会对美国国家安全造成“不利影响”，可能直接或间接暴露美国公民的个人身份信息、遗传信息或其他敏感数据，以供外国政府或机构以威胁国家安全的方式利用该信息。

2023年3月，美国再次发布《关于禁止美国政府使用对国家安全构成风险的商业间谍软件的行政命令》（Executive Order on Prohibition on Use by the United States Government of Commercial Spyware that poses Risks to National Security），指出外国政府（中国等）对美国敏感数据的利用和对监视技术（包括商业间谍软件）的“不当使用”威胁美国的安全、隐私和人权，也带来了重大的反情报风险。外国政府和机构也将商业间谍软件用于不正当目的，例如，瞄准和恐吓已知的对手，遏制异议，限制言论自由、和平集会或结社自由，在没有适当法律授权、保障措施或监督的情况下追踪或瞄准美国人等。

2024年2月，**美国发布《防止“受关注国家”访问美国的大量敏感信息和美国政府相关数据的行政命令》（Executive Order on Preventing Access to Americans’ Bulk Sensitive Personal Data and United States Government Related Data by Countries of Concern）（14117行政令）**，提出基因组数据、生物特征数据、个人健康数据、地理位置数据、财务数据和某些类型的个人标识符等六大类重点数据类型。2025年1月8日，美国司法部（DOJ）正式发布该行政令的最终实施规则（Final Rule）并宣布2025年4月8日为正式生效日。

14117行政令确立两类管控对象：

“关注国”：由司法部长和国务卿、商务部长共同认定，核心标准是：长期有严重损害美国国家安全的行为，且有极大风险会利用这些敏感数据损害美国安全的外国政府，中国、俄罗斯、伊朗、朝鲜、古巴和委内瑞拉为受关注国家；

“被覆盖的人”：不光是“关注国”政府本身，还包括：该国控股 / 控制 / 管辖的企业 / 实体、该国的政府雇员 / 承包商、受该国法律约束必须给政府交数据的公司、住在该国的外国人，以及司法部长认定的其他相关人。简单说：不光不能直接和“关注国”政府做风险数据交易，和它控制的企业、关联个人做，也会被管。

14117行政令确立两类重点数据：

批量敏感个人数据：达到一定数量门槛、能定位到具体美国人的敏感数据，包括：个人核心身份标识、精准实时地理位置 / 传感器数据、人脸 / 指纹等生物识别数据、基因 / 健康医疗数据、个人财务数据。例外：公开的法院 / 政府记录、正常的私人通信、合规的公开信息材料，不算在内。

美国政府相关数据：哪怕数量不多，只要是和现任 / 近期离任的联邦政府雇员、军方人员、政府承包商、前高官相关的敏感数据，还有和联邦政府 / 军方控制的敏感地点相关的数据，一律纳入管控 —— 因为这些数据能直接被用来搞间谍、渗透活动。

文件链接：<https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2024/02/28/executive-order-on-preventing-access-to-americans-bulk-sensitive-personal-data-and-united-states-government-related-data-by-countries-of-concern/>

3.3加州隐私法

《加州消费者隐私法案》(CCPA) 是美国的一项州级消费者隐私保护法。它专门适用于加利福尼亚州的居民（该法案将其定义为“消费者”），旨在规范对他们个人信息的保护。CCPA 后经《加州隐私权法案》(CPRA) 的修订和扩展，新法案于2023年1月1日生效。CPRA 不仅为消费者赋予了更多权利，还设立了加州隐私保护局 (CPPA) 等机构。

(1) CPRA适用范围：

只要你在加州做生意，满足以下 3 个条件任意一个，就必须受法案约束：

- 年营收超过 2500 万美元；
- 一年里买卖、共享超 10 万个加州消费者 / 家庭的个人信息；
- 一半以上的年收入，来自售卖加州消费者的个人信息。和企业共用品牌的子公司、关联公司，也必须同步遵守。

(2) CPRA确立的消费者隐私八项权利：

- **信息更正权（新增）**：你发现企业手里关于你的个人信息写错了、不准，有权直接要求企业更正，企业必须用合理的办法按你的要求修改。

- **信息删除权（升级）**：你有权要求企业删掉它收集的关于你的所有个人信息，不仅如此，企业还必须通知它把数据卖出去、分享出去的第三方、服务商，让对方也一起删掉。只有少数法定例外可以不删：比如要完成你买东西的交易、配合执法办案、合规的科研、履行等等。
- **完整知情权（大幅升级）**：你随时有权让企业清清楚楚告诉你：它收集了你哪些个人信息、从哪收集的、收集来干嘛、卖给 / 分享给了谁，甚至能要到它收集的关于你的一条条具体信息。旧版 CCPA 只能查过去 12 个月的信息，CPRA 升级后，只要不是不合理的要求，不管企业什么时候收集的信息，你都能查。
- **拒绝出售 / 共享权（核心升级）**：旧版只允许你拒绝企业“出售”你的信息，CPRA 直接把“共享”也纳入进来——你随时可以要求企业，不许把你的个人信息卖给第三方，也不许共享给第三方搞跨平台追踪、定向广告。对未成年人有额外强保护：13-16 岁必须本人同意，13 岁以下必须父母 / 监护人同意，故意违规的罚款翻倍。
- **敏感信息限制权（新增核心权利）**：法案专门划定了“敏感个人信息”，包括：身份证 / 社保号、银行卡 + 密码 / 验证码、精准实时定位、种族 / 宗教 / 性取向 / 工会身份、私人邮件 / 短信内容、基因 / 生物识别信息、健康数据、性生活信息等。你有权要求企业，这些敏感信息**只能用在给你提供正常服务的必要范围内**，不能瞎用、瞎传播、瞎拿去做用户画像，比如不能拿你的精准定位乱推广告，不能拿你的健康信息搞歧视。
- **不受报复权（升级）**：你行使上面任何一项权利，企业绝对不能给你穿小鞋：不能拒绝给你提供服务、不能给你涨价格、不能给你更差的服务质量、不能变相刁难你。当然，企业可以搞合理的会员、积分激励，不能是变相惩罚用户行使隐私权利。
- **数据泄露直接起诉权**：如果企业没做好安全措施，导致你未加密、未脱敏的个人信息被泄露、盗取，你可以直接起诉企业。赔偿标准是**最低 100 美元、最高 750 美元每人每次，或者你的实际损失，哪个高按哪个算**，哪怕你没实际亏钱，也能拿到法定赔偿。
- **自动化决策知情权**企业用算法、用户画像给你做自动化决策（比如批不批贷款、给你推什么内容 / 广告），你有权知道决策背后的逻辑，以及这个决策可能对你产生的结果。

（3）CPRA所确立的企业责任和约束：

法案不仅给了消费者权利，更给企业定了必须遵守的硬规矩，违反就会触发处罚。

- **数据收集必须“最小必要”**：企业只能收集提前跟你说清楚的、明确合法用途的信息，而且只能收集够用的，不能无底线乱收集；收集来的信息，也不能干跟说好的用途不沾边的事。同时必须提前告诉你，每类信息打算留多久，留存时间不能超过实现用途的必要时长。
- **必须清晰、提前告知**：收集你的信息时，就得明明白白告诉你：收集了哪类信息（包括敏感信息）、拿来干嘛、会不会卖 / 共享、打算留多久。不能藏在几十页的用户协议里，必须清晰、显眼，不能用套路隐瞒。
- **数据传出去，责任还要担**：企业把你的数据卖给第三方、交给服务商 / 承包商用，必须签合同，要求对方也遵守法案的隐私保护要求，还要有办法监督对方合规。如果对方违规，企业除非能证明自己完全不知情，否则也要担责。
- **必须做好数据安全保障**：企业必须建立和数据敏感程度匹配的安全措施，保护你的个人信息不被泄露、篡改、盗用，出了数据泄露，企业要担全责。
- **不能用“暗模式”套路用户**：法案明确禁止用界面设计套路用户，比如默认勾选同意、把拒绝按钮藏起来、用弹窗强制用户同意，这些都算违规。用户的同意必须是自愿、明确、知情的，不能被套路。
- **不能让用户放弃隐私权**：任何合同、用户协议里写“你自愿放弃本法案里的隐私权利”的条款，全都是无效的，法律上完全不算数。

（4）法案文本

- <https://www.caprivacy.org/cpra-resource-center/>（里面包含了CPRA和CCPA的修改比较和评注）
-  [The California Privacy Rights Act of 2020.pdf](#)
- **（中文版）** [数字法盟公益翻译小组版本](#)

三、AI在上述流程中能做什么？

（一）智能判断数据出境应选择的路径

通过问答，自动判断企业应适用的合规路径。

（二）在出境法定流程中可以自动/辅助撰写有关文件，并进行风险识别、提供合规建议

解析企业输入的业务材料（合同、架构图、数据清单等），提供三类服务：

- 一是在数据出境安全评估路径上：生成数据出境风险自评估报告，提高安全评估通过率
- 二是在个人信息出境认证路径上、在个人信息出境标准合同备案路径上：生成个人信息保护影响评估
- 三是在生成报告的同时，自动定位合规差距，提出整改建议。生成尽调报告、备忘录、TIA（数据跨境传输的风险评估）、补充性防范措施建议等。

（三）文档审查、风险识别并提供合规建议

辅助审查隐私政策、数据合同等文件的合规性。

四、P0阶段产品搭建思路

（一）用户操作界面描述（建议全部是中英双语）

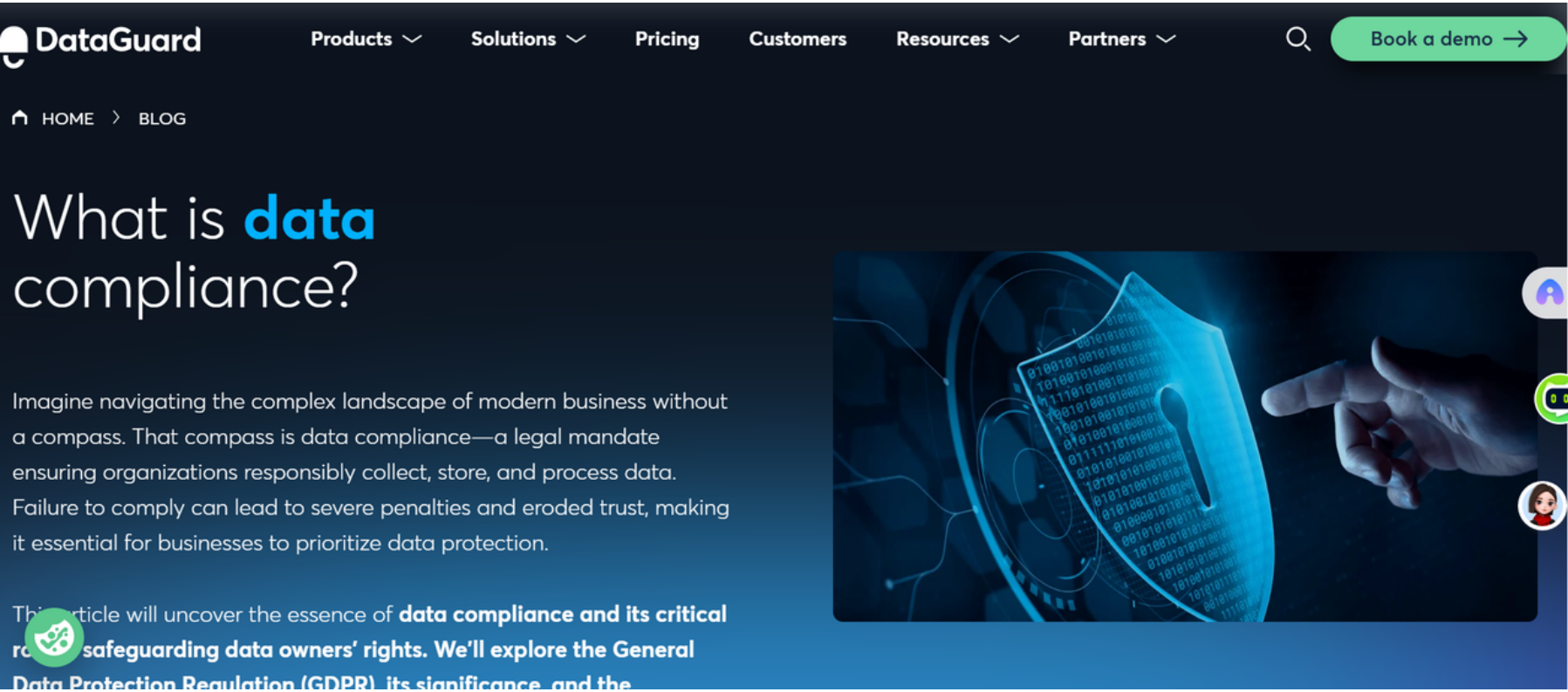
1. 首页：

1.1 “科普页面”

最上面：介绍中、美、欧、英等跨境传输框架

- **中国框架**：重点解析数据出境的“三条路径”——安全评估、标准合同、个人信息保护认证。
- **欧盟框架**：深入剖析《通用数据保护条例》（GDPR）的跨境数据传输机制与关键要求。
- **美国框架**：梳理以《加州消费者隐私法》（CCPA/CPRA）为代表的联邦及州级数据隐私与跨境规则。

大概就像DataGuard的首页界面这样子



<https://www.dataguard.com/blog/what-is-data-compliance/>

1.2 专项服务选项

下拉：介绍我们的专项服务场景

基于对上述法律体系的深度理解，我们为企业提供覆盖以下核心场景的合规解决方案：

- **从中国大陆向境外传输数据**：提供符合中国法律要求的全流程合规支持。
- **从欧盟向境外传输数据**：提供满足GDPR合法性基础（如SCCs）的合规方案。
- **从美国向境外传输数据**：协助企业应对联邦与各州复杂的数据出口管制与隐私法要求。

大概就是这个样子：



2. “从中国大陆向境外传输数据” 界面

点击“从中国大陆向境外传输数据” 进入一个界面

界面显示了我们在这个法域可以提供的具体服务选项

包括：

- ①合规路径诊断（小字写：通过智能问答，快速确定企业数据出境应适用的具体合规路径（安全评估/标准合同/保护认证））
- ②安全评估路径（小字写：生成《数据出境风险自评估报告》草案）
- ③认证/标准合同路径（小字写：生成《个人信息保护影响评估》草案）
- ④通用服务（小字写：尽调报告、合规备忘录、补充性防范措施建议、自动定位合规差距（如生成《风险与整改建议清单》等）
- 【先放一放】**
- ⑤文档智能审查（小字写：对现有的隐私政策、数据出境合同等法律文件进行合规性体检，并给出优化建议）

大概就像这样：



合规路径诊断

通过智能问答，快速确定企业数据出境应适用的合规路径（安全评估/标准合同/保护认证）

立即试用 →



安全评估路径

生成《数据出境风险自评估报告》草案，满足网信办申报要求，提高通过率

立即试用 →



认证/标准合同路径

生成《个人信息保护影响评估》草案，为认证或标准合同备案提供核心文件

立即试用 →



通用合规文件生成

生成TIA（跨境传输风险评估）、尽调报告、合规备忘录、补充性防范措施建议等

立即试用 →



自动定位合规差距

自动识别合规风险点，生成《风险与整改建议清单》，提供清晰行动指引

立即试用 →



文档智能审查

对现有的隐私政策、数据出境合同等法律文件进行合规性体检，并给出优化建议

立即试用 →

豆包AI生成

或者这样：



DPIA

基于工作流的自动化评估，结合符合行业特点的问卷模板和自动风险匹配，让DPIA评估更加精准的反应合规问题。

立即试用 →



数据分级分类

多维数据分级分类，通过强大的级别与类别定义，满足不同场景与法律要求。

立即试用 →



数据发现及资产管理

自动数据发现与元数据资产管理，支持各种主流数据库与文件格式，清晰呈现数据合规状态，清扫法律死角。

立即试用 →



数据映射

可视化方式呈现个人数据资产分布及相关数据处理活动，更加直观地对数据进行管理和监控。

立即试用 →



应急响应

提供符合法律要求的合规应急事件自动化处理，帮助您降低因处理周期长或流程纰漏导致的法律风险。

立即试用 →



主体权利管理

自动化主体权利请求管理，大幅降低企业响应合规行权的成本。结合同意管理与自动数据发现，帮您规避因内容不准确导致的诉讼风险。

立即试用 →



同意管理

匹配企业风格的同意开关界面，提供覆盖隐私政策、Cookie、用户偏好等的用户同意收集和证据留存，帮助您的企业达到监管要求。

立即试用 →



第三方管理

360度进行第三方合规管理，覆盖合同、第三方资质、第三方产品等各方面内容，避免您的企业因第三方问题导致的连带责任风险。

立即试用 →

https://www.privacyn.cn/product_vprivacy

2.1 合规路径诊断

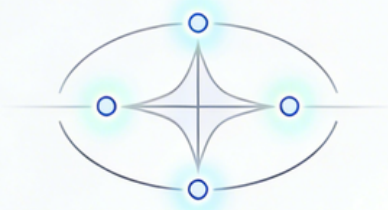
状态0：模块入口

- **界面：**用户从主界面点击“合规路径诊断”卡片进入。
- **动作：**进入一个**全屏/大浮层**的新页面，页面标题为“合规路径智能诊断”，副标题为“我们将通过几个问题，快速明确您的数据出境合规义务”。

就像这样：

合规路径智能诊断

我们将通过几个问题，快速明确您的数据出境合规义务。



开始诊断

豆包AI生成

状态1：流程引导与开始

- 界面：
 - 主区域显示流程说明：“诊断约需2分钟，请准备您的业务基本情况。所有回答仅用于本次诊断。”
 - 底部有一个醒目的“开始诊断”按钮。
- 交互：用户点击“开始诊断”按钮。

诊断约需2分钟，请准备您的业务基本情况。
所有回答仅用于本次诊断。



开始诊断

豆包AI生成

状态2：核心问题序列（动态问答）

- 界面布局：
 - 顶部进度条：显示当前进度（如“问题 1 / 5”）。

- 主问题区：
 - 问题标题：以加粗字体显示当前问题。
 - 选项区域：以单选按钮（Radio Button）或大号选择卡片的形式呈现2-5个明确选项。
 - 帮助提示：在问题下方，用灰色小字提供法律术语解释或常见业务场景举例（鼠标悬停在“？”图标上显示）。
- 底部操作区：
 - “上一步”按钮：可返回修改上一题答案。
 - “下一步”按钮：在未选择时置灰，选择后高亮可点击。

您的企业是否属于“关键信息基础设施运营者”(CIIO)？

☐ 是

☐ 否

☐ 不确定

关键信息基础设施 (CI) 通常指公共通信、能源、交通等关键行业的核心系统。

?

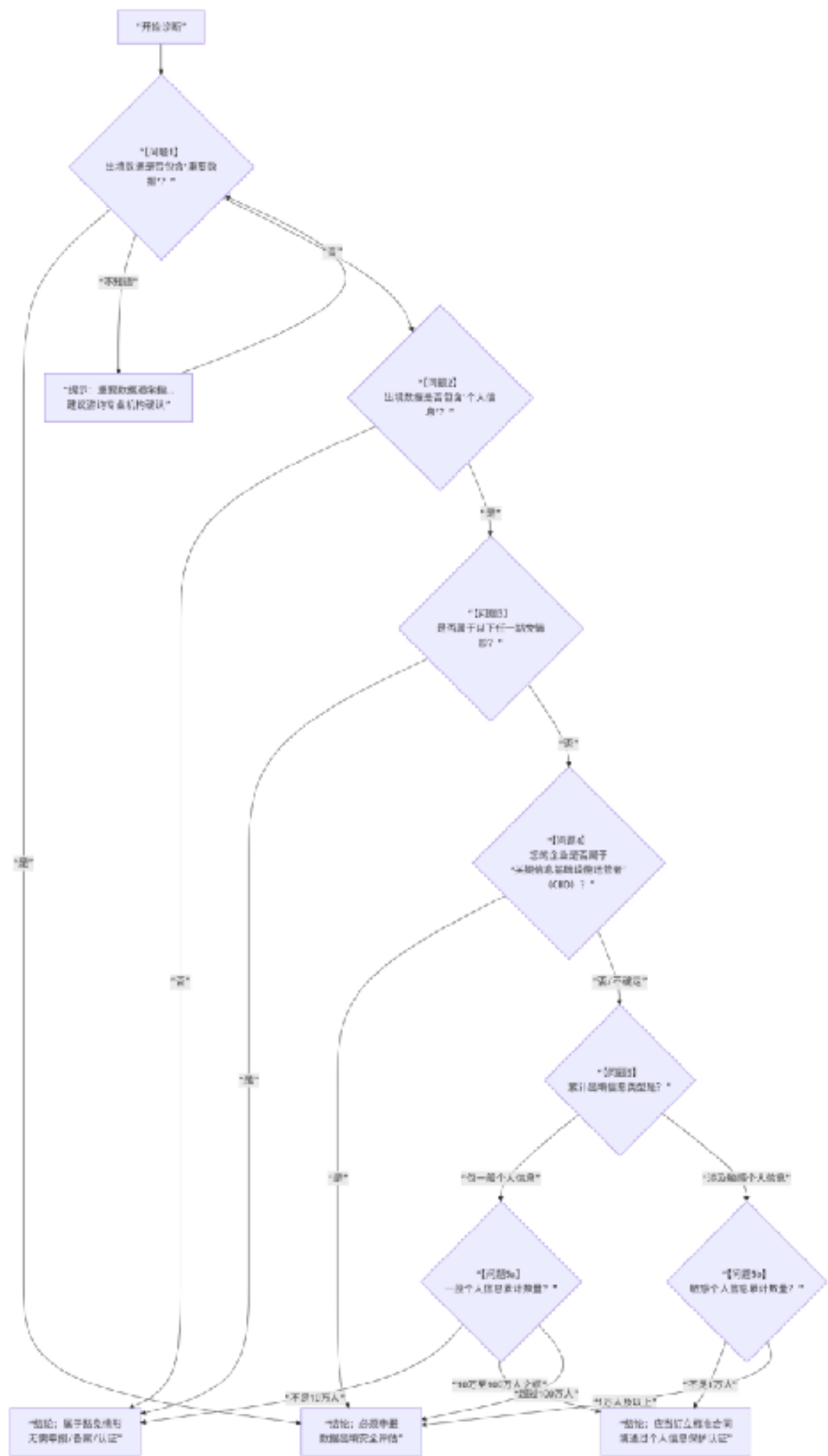
上一步

下一步

豆包AI生成

- 核心问题逻辑与跳转示例：

是用基于固定规则的“问题树”，还是把信息收集后，由 AI 的智能识别？



合规路径诊断问题设计_V2_WSC_20260326.docx

状态3：诊断结果与报告生成

- 界面：
 - 醒目结论横幅：用颜色和图标清晰展示最终诊断结果。例如：
 - 红色盾牌图标 + “必须申报数据出境安全评估”。
 - 蓝色文件图标 + “建议通过订立《个人信息出境标准合同》并备案”。
 - 绿色对勾图标 + “建议通过个人信息保护认证”。
 - 结论详解区域：以要点形式列出得出此结论的**核心判断依据**（如：因您非CII，但出境个人信息预计超过100万人，故触发安全评估）。

- **后续行动指南**：列出接下来建议的1-3个关键步骤。
- **报告生成区**：提供“生成详细诊断报告”按钮。
- **交互**：点击“生成详细诊断报告”按钮。
- **后端动作**：系统整合所有问答记录与推理逻辑，生成一份PDF/HTML格式的《合规路径诊断报告》，内容包括：用户答案摘要、法规引用、路径判定逻辑树、核心风险提示与后续行动清单。

状态4：报告下载与返回

- **界面**：弹出下载框，或在新页面展示报告。页面底部提供“完成并返回主页”或“基于此结果，开始生成评估报告”（此按钮将用户引导至“安全评估路径”或“认证/标准合同路径”模块，并携带本次诊断的会话ID作为上下文）。

✓ 诊断完成



必须申报数据出境安全评估

判断依据

- 您的企业不属于关键信息基础设施运营者（CIIO）。
- 您预估出境的一般个人信息数量超过100万人。
- 根据《数据出境安全评估办法》规定，此情形触发安全评估申报义务。

后续建议步骤

1. 准备《数据出境风险自评估报告》及相关证明材料。
2. 通过所在地省级网信办提交安全评估申报。
3. 关注审核进度，并及时回应问询。



生成详细诊断报告

在线预览报告大纲

豆包AI生成

2.2 安全评估路径

2.2.1 用户输入：结构化信息收集与文件上传

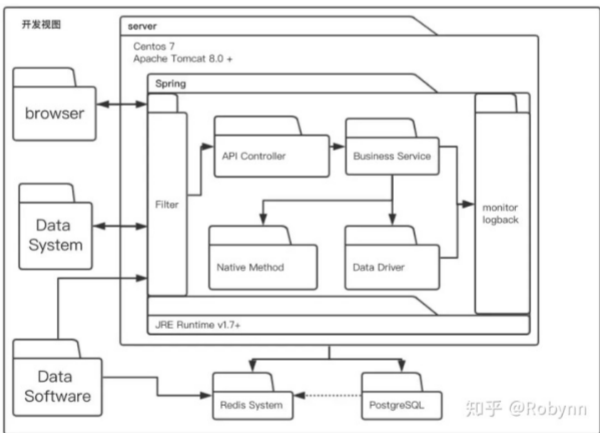
系统将通过 “表单填写”（逐步填写）与“文件上传”（批量上传） 相结合的方式，收集生成报告所需的全部信息。

输入大类	输入项描述	对应《报告》章节	采集方式建议	格式
A. 基础信息	数据处理者（境内公司）基本信息。	二、（一）1. 基本情况简介	Web表单	文本字段：公司全称、统一社会信用代码、法定代表人、所属行业。
B. 自评估工作信息	本次自评估的起止时间、组织情况、实施方式。	一、自评估工作情况	Web表单	文本描述字段。可提供引导性填空模板。



基础信息
■ 营业执照信息
· 统一社会信用代码：
· 注册号：
· 类型： 限
· 注册资本：
· 登记机关：
· 住所： 福

填写
本次
10日。
组织
信息安
组。
实施
核查、
盖“
景。

C. 数据出境场景	每个出境场景的业务描述、目的、频率、起止时间。	二、(二) 2.	动态表单（可添加多个场景）	每个场景包含：场景名、目的、合法性说明、必要性说明、频率（单选）、起止日期。	填写出境场景的目的、话、流程图、合法化同所中就特定必要（美国）送所得不出境频率：起止日				
D. 出境数据清单(核心)	详细的数据项清单，是风险评估的基础。	二、(二) 3. 数据项清单表	Excel上传 或 在线表格编辑	表头必须包含：数据项名称、内容描述、所属业务场景、是否个人信息、是否敏感个人信息、出境必要性说明、示例。	<table><tr><th>序号</th></tr><tr><td>1</td></tr><tr><td>2</td></tr><tr><td>.....</td></tr></table>	序号	1	2	
序号									
1									
2									
.....									
E. 系统与链路信息	数据在境内外的存储位置、传输链路。	二、(二) 4.	Web表单 + 文件上传（可选）	表单填写：境内存储系统、出境方式（API/文件等）、境外存储地。可上传系统架构图/数据流转图（PNG, JPG, PDF）辅助说明。					
									
F. 安全保障能力	公司数据安全管理与技术水平。	二、(三)	Web表单（勾选+描述）+ 文件上传	表单：勾选已建立的制度（如分类分级、应急预案），描述技术措施。 文件上传：可上传制度文件（PDF/DOCX）、认证证书（如等保备案证明）扫描件。	https://paperkit.net/				
G. 境外接收方信息	接收方基本情况、处理目的与安全能力。	二、(四)	Web表单	字段：接收方名称、所在国、与己方关系、处理用途。可添加多个接收方。	填写境外接收方所在国与己方处理用途、分析服务安全能2700:含标准				
H. 法律文件	与接收方签订的数据处理合同或条款。	二、(五)	文件上传（关键）	上传与境外接收方拟订或已签署的数据出境相关合同（PDF/DOCX）。系统需解析此文件。	见下文				
I. 历史合规情况	是否曾受行政处罚及整改情况。	二、(三) 4.	Web表单（单选）	选择“是/否”，若“是”则需填写说明并可上传整改完成证明。					
J. 个人信息保护	履行告知与获取单独同意的情况。	二、(三) 1. 括号内说明	文件上传 + 描述	上传告知同意页面的截图 或 隐私政策链接，并描述取得单独同意的流程。	你 为了 以外 输入 阅产 Mic				

就这样实在还不行，就把前面所述数据出境安全评估环节给网信办要提供的所有信息、文件统一按照我们的要求的格式文件或表单由一个页面统一收集。

2.2.2 系统输出：生成的交付物

处理完用户输入后，系统将生成并打包提供以下文件：

A. 核心交付物：《数据出境风险自评估报告（草案）》

- 文件名称：[企业简称]_数据出境风险自评估报告_草案_[日期].docx
- 文件格式：Microsoft Word文档（.docx），以使用户后续灵活编辑。
- 内容与结构：报告严格遵循网信办《数据出境安全评估申报指南》所附的模板结构生成。AI将自动填充从输入中提取的信息，并生成分析性文字。

附件 4

数据出境风险自评估报告（模板）

数据处理者名称：（盖章）
年 月 日

B. 输出方式

- 在线预览：用户可在浏览器中分章节查看生成的报告草案。
- 一键打包下载：提供下载按钮，将所有输出文件（A和B）打包为一个ZIP压缩文件（[企业简称]_安全评估路径输出包_[日期].zip）供用户下载。

总结：本模块通过结构化的多类型输入，驱动AI生成高度结构化、符合监管模板的核心法律文件（报告草案），并配套可操作的衍生成果（清单与建议）。整个过程旨在将非结构化的业务材料，转化为可直接用于正式申报或内部决策的标准化合规资产。

2.3 认证/标准合同路径

2.3.1 用户输入：

输入大类	对应报告章节	输入项描述	采集方式建议	格式/示例/说明
A. 处理者与出境活动基础信息	一、(一) 1. 基本情况简介 一、(一) 2. 整体业务... 一、(一) 3. 拟出境...	1. 个人信息处理者（境内公司）基本信息。 2. 整体业务与处理个人信息概述。 3. 出境场景核心描述：涉及业务、目的、范围、方式、合法性基础（如单独同意）、必要性论证。	Web表单（分步骤填写）	文本字段、下拉选择、文本框。例如：公司全称、统一代码；目的（履行合同/人力资源管理/其他）；合法性基础（已取得单独同意/为订立合同所必需等）。
B. 出境个人信息清单 (核心)	一、(一) 3. (3) 出境个人信息的规模、范围、种类、敏感程度	详细的、字段级的出境数据清单，用于自动统计规模、识别敏感信息。	Excel模板上传（强结构化）	提供标准Excel模板，必须包含列：`数据字段名`、`业务描述`、`数据类型`、`是否个人信息`、`是否敏感个人信息`、`示例数据`、`所属业务场景`。系统依赖此表自动生成“种类、敏感程度、规模”的描述。
C. 系统与存储信息	一、(一) 3. (4) 境内存储...出境链路...	数据在境内外的存储位置、传输技术链路。	Web表单 + 文件上传（可选）	表单填写：境内/境外存储系统、数据中心位置、传输方式（AF专线等）。可上传系统架构图或数据流转图（PNG/JPG/PDF）助说明。
D. 境外接收方信息	一、(二) 境外接收方情况	境外接收方的基本情况、处理用途、方式，及其安全保护能力。	Web表单	字段：接收方名称、所在国家/地区、与处理者关系、处理目的的方式。可描述或上传其安全资质证明（如SOC2报告链接）。
E. 法律文件	(评估依据)	1. 与境外接收方拟订或已签署的《个人信息出境标准合同》或含等效条款的协议。 2. 对用户生效的《隐私政策》。	文件上传（关键）	上传《标准合同》或数据处理协议（PDF/DOCX）。上传《隐私政策》（PDF或提供URL）。系统需解析合同中的权利义务条款。
F. 合规证据	一、(一) 4. 遵守法律法规情况 一、(一) 3. (2) 合法性...	1. 履行“告知-同意”义务的证据，特别是获取“单独同意”的证据。 2. 内部数据安全管理制度。	文件上传 + 描述	1. 上传“单独同意”的前端交互截图或流程录屏。 2. 上传内部管理制度文件（如《个人信息安全管理制度》.pdf）
G. 自我评估与整改情况	二、拟出境活动的影响评估情况及结论	对照《标准合同办法》第五条进行的自我评估发现的问题及整改措施。	Web表单（引导式评估）	提供基于《标准合同办法》第五条的评估清单（如：目的限制、数据最小化、安全措施等），用户勾选“符合”或“不符合”，若“不符合”需填写整改情况。

2.3.2 系统输出

核心交付物：个人信息保护影响评估报告（草案）

文件名称：[企业简称]_PIPIA_报告_草案_[日期].docx

格式：Microsoft Word (.docx)，严格遵循模板格式与样式（四号仿宋/Times New Roman，行距26磅，页边距等）。

个人信息保护影响评估报告（模板）
（出境版）

个人信息处理者名称：_____（盖章）
年 月 日

2.4 通用服务

尽调报告、合规备忘录、补充性防范措施建议自动定位合规差距（如生成《风险与整改建议清单》

2.5 文档专项智能审查

2.5.1 输入的：

包括一切与数据的收集、流转相关的协议类的文件，包括：

数据出境相关合同：例如《数据处理协议》、《数据出境标准合同》、《云服务协议》中涉及数据处理的附件或章节、与境外接收方签订的《数据安全与保密协议》等。

对用户公开的法律文件：当前线上生效的《隐私政策》或《个人信息处理规则》。

企业内部制度：《数据安全管理制度》、《个人信息保护政策》等（用于审查内外一致性）。

《个人信息出境标准合同》样例

附件 4

个人信息出境标准合同

国家互联网信息办公室 制定

《数据处理协议》样例

GF-2025-2616

数据委托处理服务合同（示范文本）

国 家 数 据 局

制 定

市 场 监 管 总 局

二〇二五年七月

金陵科技学院 XXX 项目数据安全及保密协议

甲方： 金陵科技学院 XXX（以下简称甲方）

地址： 南京市江宁区弘景大道 99 号

邮编： 211169

电话： 025-86188586

乙方： XXX 公司（以下简称乙方）

地址：

邮编：

电话：

甲方作为金陵科技学院信息化建设的管理部门，有责任确保金陵科技学院各类信息系统的运行安全和数据安全。乙方因工作需要，在金陵科技学院相关信息系统的建设、数据处理、系统运行过程中，应采取相应的技术措施和其他必要措施，保障数据安全，确保数据不被泄漏或损坏。依据《中华人民共和国数据安全法》，立约双方本着公平自愿的原则，签订下列条款共同遵守：

第一条 本协议所称数据，是指任何以电子或者其他方式对涉及金陵科技学院的信息的记录。数据处理，包括数据的收集、存储、使用、加工、传输、提供、公开等。数据安全，是指通过采取必要措施，确保数据处于有效保护和合法利用的状态，以及具备保障持续安全状态的能力。

第二条：前条所述“数据”不含下列：

甲方事先以书面明示同意的不予保密的资料、信息等；

隐私政策

华为技术有限公司及其全球的关联公司（下文简称“华为”、“我们”和“我们的”）深知隐私对您的重要性，并会尊重您的隐私。请在向华为提交个人信息之前，阅读、了解本《隐私政策》（下文简称“本政策”）。本政策适用于显示本隐私政策、或链接至本隐私政策的华为网站和产品、服务。特别的，本网站由华为技术有限公司（注册地为深圳市龙岗区坂田华为总部办公楼）运营，华为技术有限公司是该网站所收集的个人信息的信息处理者。

本政策阐述了华为如何处理您的个人信息，但本政策可能并不涉及所有可能的数据处理情境。有关收集产品或服务特定数据的信息可能由华为在特定产品或服务发布的专门隐私通知或补充声明中阐述，或者在收集数据时提供的通知中发布。

我们制定本政策的目的在于帮助您了解以下内容：

- 华为如何收集和使用您的个人信息
- 华为如何使用 Cookie 和同类技术
- 华为如何披露您的个人信息
- 您在个人信息处理活动中的权利
- 华为如何保护您的个人信息
- 华为如何处理儿童的个人信息

2.5.2 输出的：《数据出境合同（法律文件）合规审查报告》

- 格式：**Microsoft Word 文档 (.docx)，便于用户后续编辑和批注。
- 内容结构：**
 - 文件概要：**列出已审查的文件名称、审查所依据的主要法律法规框架（如中国《个人信息保护法》、欧盟GDPR标准合同条款 SCCs）。
 - 总体合规评级：**给出一个总结性判断（例如：“整体风险中等，需重点关注以下5项缺失与高风险条款”）。
 - 条款级审查发现（报告主体）：**以清单形式逐项列出问题，每项包含：
 - 定位：**问题所在的文件、章节、页码/条款号。
 - 原文引用：**摘录有问题的合同原文。
 - 问题类型：**标识为“缺失条款”、“定义模糊”、“责任限制过度”、“与法规冲突”、“与实践不一致”等。
 - 风险分析：**解释该问题可能引发的法律、商业或操作风险（例如：“此模糊表述可能导致在数据泄露时责任界定不清”）。
 - 法规/标准依据：**引用相关的法律法规条文、监管要求或行业最佳实践。
 - 修改建议：**提供具体的、可供参考的修改文本或新增条款草案。

3. “从欧盟向境外传输数据”界面



SCC标准合同审查

智能解析欧盟委员会通过的标准合同条款（SCCs），确保其完整、有效，并映射至您的数据处理活动

立即分析



BCR（约束性公司规则）

辅导跨国集团设计符合EDPB指南的BCR方案，构建集团内部数据跨境传输的合规体系

立即分析



DPIA（数据保护影响评估）

遵循GDPR第35条要求，通过结构化流程自动化识别和评估高风险处理活动，生成评估报告



TIA（跨境传输影响评估）

专项评估向欧盟境外（第三国）传输数据的风险，重点分析目的地国法律环境是否符合欧盟基本权利保障标准

豆包AI生成

3.1 SCC审查

输入：SCC



EUROPEAN
COMMISSION

Brussels, 4.6.2021
C(2021) 3972 final

COMMISSION IMPLEMENTING DECISION (EU) .../...

of 4.6.2021

**on standard contractual clauses for the transfer of personal data to third countries
pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council**

(Text with EEA relevance)

EN

EN

输出：

输出的：《SCC合规审查报告》

- **格式：**Microsoft Word 文档 (.docx)，便于用户后续编辑和批注。
- **内容结构：**

- **文件概要：**列出已审查的文件名称、审查所依据的主要法律法规框架（如中国《个人信息保护法》、欧盟GDPR标准合同条款SCCs）。
- **总体合规评级：**给出一个总结性判断（例如：“整体风险中等，需重点关注以下5项缺失与高风险条款”）。
- **条款级审查发现（报告主体）：**以清单形式逐项列出问题，每项包含：
 - **定位：**问题所在的文件、章节、页码/条款号。
 - **原文引用：**摘录有问题的合同原文。
 - **问题类型：**标识为“缺失条款”、“定义模糊”、“责任限制过度”、“与法规冲突”、“与实践不一致”等。
 - **风险分析：**解释该问题可能引发的法律、商业或操作风险（例如：“此模糊表述可能导致在数据泄露时责任界定不清”）。
 - **法规/标准依据：**引用相关的法律法规条文、监管要求或行业最佳实践。
 - **修改建议：**提供具体的、可供参考的修改文本或新增条款草案。

3.2 BCR审核

输入：

Recommendations



Recommendations 1/2022 on the Application for Approval and on the elements and principles to be found in Controller Binding Corporate Rules (Art. 47 GDPR)

Adopted on 20 June 2023

Adopted

1

输出：

输出文件名称示例：[公司名称]_BCR-C_合规审查报告_[日期].pdf/docx

报告核心结构如下：

一、 报告摘要

审查对象：[上传的BCR文件名称及版本]

整体合规评级：

- 基本合规：结构完整，核心要素齐全，风险可控。
- 部分缺失：存在关键章节或承诺缺失，需重点补充。
- 高风险：存在多处与EDPB建议严重不符的表述，或缺乏可执行性。

主要发现摘要：

- 发现的问题总数。
- 高风险问题数量及简述（如：未明确指定欧盟责任主体、缺少第三方受益人权利条款）。

二、详细审查结果

审查模块	审查要点	审查结果	具体问题描述与定位	改进建议 / 标准表述参考
结构完整性	是否包含所有EDPB要求的核心章节？（如：约束力、责任、范围、数据保护原则、权利、TIA、更新机制等）	完整/部分缺失/严重缺失	例如：“未发现‘目的地国法律风险评估’章节。”	建议增加“第X章：第三国法律与实践的合规保障”，并包含风险评估、补充措施、政府访问通知等子章节。
法律约束力	是否明确规定了BCR对集团成员的内部约束力（如通过集团协议）？	明确/模糊/缺失	例如：“文本仅称‘所有成员应遵守’，未说明具有法律约束力的实现机制。”	建议明确规定：“本BCR通过《集团数据保护协议》对全体成员产生法律约束力，该协议为本文档附录一。”
法律约束力	是否创建了可被数据主体强制执行的第三方受益人权利？	是/否	例如：“全文未提及数据主体可作为第三方受益人强制执行BCR条款。”	【高风险】必须增加专门条款，例如：“数据主体享有本BCR第Y章（数据保护原则）与第Z章（数据主体权利）所载权利的第三方受益人权利，可直接向[欧盟责任主体]主张。”
责任与赔偿	是否明确指定了位于欧盟的责任主体，并承诺其为非欧盟成员的违规承担连带赔偿责任？	是/否	例如：“提及了‘总部将负责协调’，但未明确其为本文件下的法定赔偿责任主体。”	明确声明：“[欧盟实体A]作为本BCR的责任主体，同意为非欧盟成员的违规行为向数据主体承担赔偿责任。”
数据保护原则	对合法性基础的描述是否穷尽且具体？（如：仅列出“合法利益”，未说明评估流程）	具体/笼统/缺失	例如：“合法性基础列表为‘根据适用法律’，过于模糊。”	建议列出所有依赖的基础（同意、合同、法定义务、重大利益、公共任务、合法利益），并对“合法利益”的平衡测试要求做简要说明。
数据保护原则	关于向集团外传输（Onward Transfer）的限制是否明确？	明确/模糊	例如：“规定‘可向合作伙伴提供数据’，但未设定保护前提。”	必须增加：“向非BCR成员的第三方传输数据，必须确保其提供与GDPR实质同等的保护水平，例如通过签订欧盟标准合同条款（SCCs）。”
第三国法律（TIA）	是否包含目的地国法律风险评估的承诺和义务？	是/否	【高风险】“未发现相关承诺。”	必须增加章节，承诺在传输前评估目的地国法律（特别是政府数据访问权）是否妨碍BCR履行，并承诺在必要时采取补充措施（如加密）或暂停传输。
第三国法律（TIA）	是否规定了收到政府数据访问请求时的通知义务？	是/否	例如：“未规定数据进口方需将政府请求通知出口方。”	建议增加条款：“数据进口方在收到具有法律约束力的政府数据披露请求时，应立即通知数据出口方，并尽可能挑战不合法请求。”
可读性与可执行性	文本是否使用清晰、平实的语言？是否存在大量未定义的内部术语或缩写？	清晰/晦涩	例如：“频繁使用‘GPP’、‘CoC’等未定义的内部缩写。”	建议添加“定义”章节，解释所有专业术语和内部缩写。确保文本能被员工和非专业律师理解。
可读性与可执行性	内部有效性机制（培训、审计、投诉处理、DPO）的描述是否具体，包含频率、责任方和流程？	具体/笼统	例如：“‘将定期进行审计’，未说明频率、执行方和报告对象。”	建议具体化，例如：“集团内部审计部门将每年对高风险成员进行一次数据保护审计，审计结果直接报告至首席隐私官和集团董事会。”

三、 核心风险与优先级排序

- 必须立即修改（高风险）：列出所有可能导致BCR无法获得批准或产生重大法律风险的条款（如：缺少责任主体、无第三方受益人权利）。
- 建议优化（中风险）：列出内容存在模糊、不完整，可能影响执行或引发争议的条款。
- 完善建议（低风险）：列出提升文本专业性、可读性和可操作性的建议。

3.3 DPIA草案生成

输入：

步骤	输入项名称	内容说明/示例	输入方式	是否核心	填写示例
1. 识别需求	1.1 项目名称	DPIA所针对的具体项目或处理活动的名称。	短文本	是	
1. 识别需求	1.2 项目简要目标	简述项目希望实现的目标或提供的服务。	段落文本	是	本项目的目标是通过分析用户在本平台的浏览、点击及购买历史数据，构建用户画像和偏好模型。此模型将用于向用户提供个性化的产品推荐，以提升用户体验、增加用户粘性，并最终提高平台的核心业务转化率。
1. 识别需求	1.3 需要进行DPIA的主要理由	基于GDPR第35条，简述为何此处理可能带来高风险（如：大规模处理、系统监控、涉及特殊类别数据等）。	多选/文本	是	本次处理活动需要进行DPIA，主要基于以下两点理由：首先，该项目涉及对大规模数据主体（预估超过百万人）的行为数据进行分析，构成了系统性的大规模监控；其次，分析模型将利用用户的购买记录等数据间接推断出与健康相关的消费偏好，这可能会涉及对特殊类别数据（GDPR第9条）的间接处理，从而对数据主体的基本权利与自由带来较高风险。
2. 描述处理活动	2.1 数据处理流程图	描述或图示数据从收集到删除的全流程，包括数据在内部及与外部的流转。	文件上传/绘图	是	
2. 描述处理活动	2.2 处理的数据类型	例如：基础身份信息、联系方式、健康数据、生物识别信息、财务信息等。	多选（可自定义）	是	
2. 描述处理活动	2.3 是否涉及特殊类别数据	GDPR第9条规定的数据（如：揭示种族、政治观点、宗教信仰、生物识别、健康等）。	单选（是/否）	是	
2. 描述处理活动	2.4 预计涉及的数据主体数量	大致估算受影响的个人数量级（如：千人、万人、十万人等）。	下拉选择	是	
2. 描述处理活动	2.5 数据保留期限	计划保存数据的时间长度或确定期限的标准。	短文本	是	
2. 描述处理活动	2.6 是否涉及数据跨境传输	处理活动是否涉及将个人数据传出欧洲经济区（EEA）。	单选（是/否）	是	
3. 咨询过程	3.1 计划咨询的内部部门	例如：法务、信息安全、产品、市场等。	多选	否	
3. 咨询过程	3.2 是否计划咨询外部专家	例如：律师、安全顾问等。	单选（是/否）	否	
3. 咨询过程	3.3 是否计划征求数据主体意见	说明计划如何（如通过调查）或为何不征求用户意见。	单选+短文本	是	
4. 必要性与相称性	4.1 处理活动的合法性基础	选择所依赖的GDPR第6条合法性基础（如：同意、合同履行、合法利益等）。	多选	是	
					为了实现个性化的产品推荐这一合法目的，收集并处理用户的浏览、点击历史及基本人口统计信息是必要的，因为这些数据是建立精准用户偏好的

4. 必要性与相称性	4.2 处理是否为实现目的所必需	解释处理活动对于实现既定目标是否是绝对必要且无更小侵害的方式。	段落文本	是	核心基础。我们将遵循数据最小化原则，仅收集与推荐算法直接相关的必要字段（如商品ID、点击时间戳），而不会处理无关的个人信息（如通讯录、精确位置等）。目前，尚未发现能够达成相同目标但对个人权利侵害更小的替代性方案。
4. 必要性与相称性	4.3 计划向数据主体提供的信息	简述将通过隐私政策等方式告知用户哪些关键信息。	段落文本	是	我们将在《隐私政策》的“我们如何使用您的信息”章节中，以清晰易懂的语言向数据主体说明：我们将基于您的浏览和交互行为创建用户画像，用于向您展示更相关的商品和服务。同时，我们会明确列出处理此类个人数据的法律依据（例如合法利益），并告知您有权通过账户设置调整个性化推荐偏好或选择退出。此外，还将说明数据将被保留至您关闭账户后24个月，之后将被匿名化或删除。
5. 识别与评估风险	5.1 已识别的风险列表	逐条描述可能对个人权利自由造成的风险（如：未经授权访问、数据泄露、歧视性决策等）。	列表文本（每行一条）	是	
5. 识别与评估风险	5.2 风险可能性评估	对每条风险，评估其发生的可能性（低/中/高）。	下拉选择	是	
5. 识别与评估风险	5.3 风险影响严重性评估	对每条风险，评估其若发生对个人的影响程度（低/中/高）。	下拉选择	是	
6. 降低风险的措施	6.1 针对高风险的措施	针对评估为高风险的项目，描述计划采取的额外技术或组织措施（如：强化加密、匿名化、增加人工审核）。	列表文本（风险-措施对应）	是	
7. 签署与记录	7.1 DPIA负责人	负责完成此DPIA的人员姓名与职位。	短文本	是	
7. 签署与记录	7.2 数据保护官（DPO）意见	DPO提供的建议摘要（如：同意、需修改、高风险需咨询监管机构）。	段落文本	是	经审阅，本DPIA草案已初步识别出涉及大规模分析及间接推断敏感偏好所带来的主要风险。草案中提出的“在推荐结果生成路径中实施匿名化聚合计算”、“定期审计模型输出以防范歧视性结果”及“提供清晰的用户控制开关”等风险消减措施是合理且必要的。建议：同意在实施上述全部消减措施的前提下推进项目。项目上线后，应每半年进行一次合规复审，以确保风险控制的有效性。

输出：

Sample DPIA template

This template is an example of how you can record your DPIA process and outcome. It follows the process set out in our DPIA guidance, and should be read alongside that guidance and the [Criteria for an acceptable DPIA](#) set out in European guidelines on DPIAs.

You should start to fill out the template at the start of any major project involving the use of personal data, or if you are making a significant change to an existing process. The final outcomes should be integrated back into your project plan.

Submitting controller details

Name of controller	
Subject/title of DPO	
Name of controller contact /DPO (delete as appropriate)	

3.4 TIA草案生成

输入：

步骤	输入项名称	内容说明/示例	输入方式建议	是否核心
1. 了解您的传输	1.1 数据出口方（欧盟内）名称	例如：XYZ 欧洲有限公司	短文本	是
1. 了解您的传输	1.2 数据进口方（第三国）名称	例如：ABC 科技有限公司	短文本	是
1. 了解您的传输	1.3 进口方所在国家/地区	例如：美国	下拉选择	是
1. 了解您的传输	1.4 传输的主要目的	例如：提供IT支持、进行数据分析、在云端存储业务数据	段落文本	是
1. 了解您的传输	1.5 传输的数据类别	例如：员工联系方式、客户订单信息、系统日志	列表文本	是
1. 了解您的传输	1.6 是否涉及特殊类别或敏感数据	GDPR第9条定义的数据（如健康、生物识别、政治观点等）	单选（是/否）	是
1. 了解您的传输	1.7 涉及的数据主体类别	例如：员工、客户、供应商	多选	是
1. 了解您的传输	1.8 传输频率	例如：一次性、偶尔、定期	下拉选择	是
2. 识别所用传输工具	2.1 本次传输基于的合规工具	☐ 充分性决定 ☐ SCCs ☐ BCRs ☐ 行为准则 ☐ 认证机制 ☐ 第49条克减	单选	是
2. 识别所用传输工具	2.2 是否需要执行TIA?	根据所选工具自动判断（如选SCCs/BCRs则“是”）。	自动判断/显示	是
3. 评估目的地法律与实践	3.1 是否对目的地国法律（特别是政府数据访问）进行了评估?	☐ 是，已评估 ☐ 否，未评估	单选	是
3. 评估目的地法律与实践	3.2 评估的主要发现摘要	简述评估结论，例如：“该国法律赋予政府宽泛的数据访问权，可能影响SCCs的有效性。”	段落文本	建议
3. 评估目的地法律与实践	3.3 初步结论：传输工具在目的地是否仍然有效?	☐ 是，有效 ☐ 否，可能无效	单选	是
4. 识别补充措施	4.1 已实施的技术性补充措施	例如：传输前强加密、数据假名化、端到端加密	列表文本	是
4. 识别补充措施	4.2 已实施/计划的合同性与组织性补充措施	例如：合同中加入异议政府请求条款、定期发布透明度报告、内部访问控制	列表文本	是
4. 识别补充措施	4.3 采用补充措施后，传输是否可被视为有效?	☐ 是，可进行 ☐ 否，应暂停	单选	是
5. 实施步骤与意见	5.1 需采取的关键行动（如修改合同、部署加密）	例如：1. 更新与进口方的数据处理协议 2. 在6月前对所有传输数据启用AES-256加密	列表文本	建议
5. 实施步骤与意见	5.2 数据保护官（DPO）意见摘要	DPO对TIA结论和补充措施的建议，例如：“同意在实施全部加密措施后推进。”	段落文本	是
6. 定期复审	6.1 设定的下次复审日期	例如：2025-01-15	日期选择	是

输出：

TRANSFER IMPACT ASSESSMENT

Based on Transfer Impact Assessment, Draft guide for public consultation until 12 February 2024, published by CNIL, France.

Step 1 – Know Your Transfer

In order to ensure an essentially equivalent level of protection for the data transferred, wherever it is being processed, first it is necessary to describe the transfer.

To complete the table below, you can use your pre-existing internal documentation, such as the record of processing activities or the contract governing the transfer. You can also contact the data importer.

Step 1: Know Your Transfer	
Exporter Name	
Contact Point and Contact Details	
Exportation Country	
Exporter Qualification in the Context of the Data Transfer	☐ Controller ☐ Joint Controller ☐ Processor <i>If "Processor" or "Joint Controller", provide the name of the Controller:</i>
Importer Name	
Contact Point and Contact Details	
Importation Country	
Importer Qualification in the Context of the Data Transfer	☐ Controller ☐ Joint Controller ☐ Processor <i>If "Processor" or "Joint Controller", provide the name of the Controller:</i>
Nature of the Data Importer's Activities	☐ Commercial ☐ Public sector ☐ Non-profit ☐ Other <i>If "Other", specify:</i>
Transfer Start Date	
Intended Transfer End Date or Transfer Duration	
Transfer Purpose(s) and Processing Activities Undertaken by the Importer Regarding the Transferred Data (e.g. IT support, marketing, provision of cloud software, data hosting)	

4. “从美国向境外传输数据” 界面



4.1对华数据流动合规

（基于14117号行政令及其实施细则）

此模块旨在解决企业向“受关注国家”（尤其是中国）传输数据时的禁令合规问题。

输入：

1.数据清单（类比中国框架）

输入大类	输入项描述	对应《报告》章节	采集方式建议	格式	示例																				
D. 出境数据清单 (核心)	详细的数据项清单，是风险评估的基础。	二、(二) 3. 数据项清单表	Excel上传 或 在线表格编辑	表头必须包含：数据项名称、内容描述、所属业务场景、是否个人信息、是否敏感个人信息、出境必要性说明、示例。	<table><tr><th>序号</th><th>数据项名称</th><th>内容描述</th><th>出境必要性</th><th>示例</th></tr><tr><td>1</td><td></td><td></td><td></td><td></td></tr><tr><td>2</td><td></td><td></td><td></td><td></td></tr><tr><td>...</td><td></td><td></td><td></td><td></td></tr></table>	序号	数据项名称	内容描述	出境必要性	示例	1					2					...				
序号	数据项名称	内容描述	出境必要性	示例																					
1																									
2																									
...																									

2.实体清单

项目	子项	数据格式/选项	说明/示例
实体清单输入	1.外部实体清单	文件上传 (.csv/.xlsx) 或 表单逐条添加	需包含字段：实体全称、注册国家/地区、统一社会信用代码/税号（可选）、股权结构说明（如“中资控股XX%”）
	2.内部员工清单（如适用）	文件上传 (.csv/.xlsx)	用于筛查“被覆盖的人”，需包含字段：员工姓名、国籍、属部门、岗位

输出：

4.2加州隐私合规

（基于加州CPRA及其修正案）

输入：

输入类别	具体输入项	输入方式建议	是否必填	说明/示例
1. 企业信息	1.1 企业名称、DBA（经营用名）	文本表单	是	用于报告抬头和身份识别。
	1.2 CPRA适用性自检	选择题	是	例如：年收入是否超过\$2500万？是否处理超10万加州消费者个人信息？年收入50%以上是否来自出售个人信息？
	1.3 隐私政策链接/文本	文件上传或URL	是	用于分析合规性。
2. 数据处理活动	2.1 数据流图谱（或简化问卷）	问卷引导或图表上传	是	描述从收集、使用、共享到删除的数据生命周期，明确目的、存储地、共享方。
	2.2 处理的数据类别清单	多选+自定义	是	包含：基础PII、敏感个人信息（SPI，如健康、生物识别、精确位置等）。
	2.3 数据收集的合法性基础	多选（同意、合同履行、合法利益等）	是	明确每类主要处理活动的法律依据。
	2.4 数据留存期限政策	文本描述（每类数据）	是	说明每类数据的存储时长及确定依据。
3. 消费者权利响应机制	3.1 现有DSR受理渠道	描述+URL/截图	是	说明消费者如何提交知情、访问、删除、选择退出等请求。
	3.2 身份验证方法	描述	是	描述如何验证消费者身份以防止信息泄露。
	3.3 内部处理流程与SLA	描述	是	说明请求如何在内部流转及响应时限。
4. 技术与管理措施	4.1 敏感信息（SPI）使用清单	多选+描述	是	说明哪些业务使用了SPI（如精准广告、信用评估）。
	4.2 向第三方出售/共享数据情况	是/否 + 清单	是	如“是”，需提供第三方类别、目的及合同保障说明。
	4.3 现有安全措施概述	多选+描述	是	如加密、访问控制、员工培训等。
	4.4 用户界面（UI/UX）示例	网站/APP关键页面截图	建议	用于“暗模式”分析，如同意弹窗、隐私设置页。

输出：《加州CPRA合规全景报告》

报告章节	内容说明	对应输入模块
执行摘要	总体合规评级（如：基本合规、部分缺失、高风险），核心发现与亟待解决的高风险项列表。	综合
第一章：企业适用性与范围	基于输入1.2，明确企业是否受CPRA管辖及法律依据。	企业信息
第二章：数据处理活动合规分析	数据映射可视化：展示输入2.1的数据流图。	数据处理活动
	合法性基础匹配度：分析输入2.3是否充分、明确。	数据处理活动
	留存期限评估：核对输入2.4是否合理、有据。	数据处理活动
第三章：消费者权利保障评估	DSR机制完备性：分析输入3.1-3.3的渠道、流程、时限是否符合法规。	消费者权利响应机制
	差距与建议：指出漏洞（如缺少"选择退出"按钮）并提供整改方案。	消费者权利响应机制
第四章：敏感信息与第三方管理	SPI使用合规性：审查输入4.1的使用是否超出"必需"范围。	技术与管理措施
	数据出售/共享风险评估：基于输入4.2，评估第三方风险及合同保障。	技术与管理措施
	"暗模式"扫描结果：基于输入4.4，识别并截图指出UI设计中的潜在违规点。	技术与管理措施
第五章：行动清单与优先级	将报告中所有发现的问题转化为可执行的待办任务，按风险等级（高、中、低）排序，并给出具体操作建议。	综合

（二）我们知识库需要有的内容

- (1) 构建信源库，确定几个信源渠道；有一些公共的需要付费的数据库**北大法宝、威科先行、westlaw等**
- (2) 构建扩大信源的功能：能够主动搜索、识别互联网上的可靠信源，屏蔽掉不可靠信源，将有关信源及时更新到信源库中。
- (3) 构建更新知识的功能：将信源的信息及时更新到知识库中。

具体需要有的东西

1.东亚框架（以中、韩为主）

(1) 中国框架（规范与案例）

我国《个人信息保护法》《数据安全法》《网络安全法》及《出境评估办法》主要限制重要数据、个人信息出境。尤其《出境评估办法》，适用范围明确限于重要数据和个人信息出境。不涉及该两类数据的，目前我国生效法律法规中没有明确的出境限制。

 路径一：数据出境安全评估相关规范、指南

1. 《数据出境安全评估办法》（2022.07.07）

正式的官方文件依据是《数据出境安全评估办法》。
官方的注解可参见“《数据出境安全评估办法》答记者问”。

2. 《数据出境安全评估申报指南(第三版)》（2025.06.27）

 数据出境安全评估申报指南（第三版）.docx
改动的地方可见《数据出境安全评估申报指南|第二版与第三版逐条对比》。 数据出境安全评估申报指南第二版与第三版逐条对比-数据信任与治理-20250630.pdf

3. 《数据出境安全评估申报指南(第二版)》（2024.03.22）

 数据出境安全评估申报指南（第二版）.doc

4. 《数据出境安全评估申报指南(第一版)》（2022.09.01）

- a. 为了指导和帮助数据处理者规范、有序申报数据出境安全评估，国家互联网信息办公室编制了《数据出境安全评估申报指南（第一版）》，对数据出境安全评估申报方式、申报流程、申报材料等具体要求作出了说明。数据处理者因业务需要确需向境外提供数据，符合数据出境安全评估适用情形的，应当根据《数据出境安全评估办法》规定，按照申报指南申报数据出境安全评估。我
 - b.  《数据出境安全评估申报指南（第一版）》.docx
 批注版《数据出境安全评估办法》答记者问.doc
 - c. 中英双语版：世辉律师事务所，https://mp.weixin.qq.com/s/_p2RMztk48a7mygM-8sOhg
 - d. 辅助文件
 - i. 江苏： 江苏省数据出境安全评估申报工作指引（第一版）.pdf
 - ii. 海南： 海南省数据出境安全评估申报工作指引(第一版).pdf
 - iii. 上海：《发布 | 数据出境安全评估申报工作实务问答（一）》；《发布 | 数据出境安全评估申报工作实务问答（二）》
 - iv. 浙江：《浙江省数据出境安全评估申报工作问答》；《浙江省数据出境安全评估申报材料指引》
 - e. 其他讯息
 - i. 《香港个人资料私隐专员公署就《数据出境安全评估办法》生效发布提醒》
5. 苏州市互联网信息办公室即日起，在“苏商通”门户网站、移动端APP推出苏州市数据出境安全评估申报备案平台，为企业“一站式”申报数据出境安全评估开通便捷通道，提供工作指引、申报备案、异议申报、申报咨询、政策动态五类服务。
- 网站入口：<https://jy.suzhou.com.cn/dataexport/#/export-index>

 路径二：个人信息出境认证路径相关规范

- 2025年10月17日，网信办联合市监总局发布《个人信息出境认证办法》。
 - 文件：《个人信息出境认证办法》
 - 答记者问：《个人信息出境认证办法》答记者问
 - 解读：数据何规，《个人信息出境认证实务问答》
- 2025年9月29日，市场监管总局（国家标准委）批准发布《数据安全技术 个人信息跨境处理活动安全认证要求》（GB/T 46068—2025）推荐性国家标准，将于2026年3月1日正式实施。

- GB/T 46068《数据安全技术个人信息跨境处理活动安全认证要求》国家标准已发布。为贯彻落实《个人信息出境认证办法》（国家互联网信息办公室、国家市场监督管理总局令第20号），确保个人信息出境认证工作有序实施，现将有关要求明确如下：自本公告发布之日起，《关于实施个人信息保护认证的公告》（国家市场监督管理总局、国家互联网信息办公室公告2022年第37号）附件《个人信息保护认证实施规则》中，涉及跨境处理活动的个人信息保护认证依据标准变更为GB/T 35273、GB/T 46068。

- 一图读懂：《我国个人信息跨境安全管理领域首项国家标准发布（附一图读懂）》

- 《个人信息出境认证专业机构备案指南》

- 落实《个人信息出境认证办法》第十二条规定，国家互联网信息办公室会同国家数据局完成中国网络安全审查认证和市场监管大数据中心、中央网信办（国家网信办）数据与技术保障中心、北京赛西认证有限责任公司3家机构的个人信息出境认证备案审核。个人信息处理者通过认证方式向境外提供个人信息的，可以向上述机构申请个人信息出境认证。为便于个人信息出境认证专业机构办理备案手续，国家互联网信息办公室上线个人信息出境认证专业机构备案系统，网址为<https://sjcj.cac.gov.cn>。备案材料具体要求和流程详见《个人信息出境认证专业机构备案指南》。

路径三：中国个人信息出境标准合同的规定

网信办指南

- 2024年3月22日，网信办发布了《个人信息出境标准合同备案指南（第二版）》
 -  个人信息出境标准合同备案指南（第二版）.docx
 - 《实务简评 | 安全评估及Scc第二版增改删了哪些内容？》
- 2023年5月30日，国家网信办发布了《个人信息出境标准合同备案指南（第一版）》
 - Word版：  《个人信息出境标准合同备案指南（第一版）》.docx
 - 地方网信的指引：
 - 《北京市个人信息出境标准合同备案指引》
 - 《上海市网信办关于个人信息出境标准合同备案的通知》
 - 解读参考：
 - 安杰世泽杨洪泉，《《个人信息出境标准合同》合规落地全解析 | 威科先行》；汇业黄春林，《汇业评论 | 个人信息出境标准合同备案实务问题解读》；中伦陈际红，《对比速览 | 个人信息保护影响评估模板VS风险自评估模板》
 - 财经E法，《个人信息出境有了第三条路，对企业意味着什么？》；
 - 英文翻译：网安寻路人，《《个人信息出境标准合同备案指南（第一版）》（英文全文翻译）》

正式版规定

- 2023年2月25日，中国大陆正式发布了《个人信息出境标准合同办法》
 - 官方解释：《个人信息出境标准合同办法》答记者问
 - 文本：  个人信息出境标准合同.pdf；  《个人信息出境标准合同》标准合同范本.docx
 - 新旧对比：中伦，《修改对比及要点速览》
 - 解读参见：6
 - 公安三所，《专家解读 | 中国个人信息跨境流动的“标准合同”规则解读》；
 - 君合孙博，《《个人信息出境标准合同》的适用与重点》；张继红，《夜线约见：为数据出境设置“红绿灯”》【电视访谈】；年利达，《China's standard contract for cross-border data transfers released: key implications》；数据何规，《再谈数据出境，三架马车落地之际的疑思》；中伦蔡鹏，《个人信息出境标准合同落地，企业应对的“道”与“法”》；一川Law，《一川快评 | 数据出境并无坦途：评《个人信息出境标准合同办法》》；君合，《君合法评 | 尘埃落定-标准合同落地八大关注点》；张丹，《《个人信息出境标准合同办法》二十大症结问题解读》；

- **英文翻译：**（非官方）德勤，[📄 Measures for the Standard Contract for Personal Information Cross-Border Transfer_v1.1_Bilingual.pdf](#)；王新锐团队翻译；[📄 \(英文版\) 个人信息出境标准合同.docx](#)
- **逐条解读：**植德王艺，[📄 230227_个人信息出境标准合同办法及标准合同逐条解读1.0版_MT.pdf](#)
- **境内处理者和境外接收方义务梳理（To-do List）：**[📄 230227_个人信息出境标准合同办法及标准合同逐条解读1.0版_MT.pdf](#)

征求意见稿

- 2022年7月，中国大陆发布了《个人信息出境标准合同规定（征求意见稿）》
 - **解读参见：**史宇航，《挖·规则 | 数据出境又一村：《个人信息出境标准合同规定（征求意见稿）》发布》；陈际红，《中国版标准合同条款揭开面纱，能否成为个人信息出境的通途（一）？》；方达合规组，《《个人信息出境标准合同规定（征求意见稿）》简析及政府审批跨境传输要求的展望》；

(2) 韩国框架

韩国的主要个人数据保护法规包括《个人信息保护法》（PIPA）以及《信息通信网络的利用促进及信息保护法》（Network Act，网络法）。此外，管理特定类型个人信息的其他法规包括《信用信息使用和保护法》（Credit Information Use and Protection Act）（“信用信息法”）和《位置信息保护和使用法》（Act on the Protection and Use of Location Information）（“位置信息法”）。韩国还颁布了两项重要的公共数据保护法律，即官方信息公开法（Official Information Disclosure Act）和促进公共数据提供和使用法（Act on Promotion of Provision and Use of Public Data）的法律。此外，韩国于2021年10月19日颁布了《关于数据产业和数据利用促进的框架法》（Framework Act on Promotion of Data Industry and Data Utilation）（框架法）。这是世界上第一部规范数据产业的框架法。为了规定法律要求和执行所必需的事项，韩国还颁布了一些总统令，例如个人信息保护法执行令（Enforcement Decree of the Personal Information Protection Act，PIPA执行令）。

【补充案例】

2.欧洲框架（以欧盟、英国为主）

(1) 欧盟框架

欧盟是目前数据出境合规风险最高、案件最集中的经济体，欧盟应该是我们重点关注的法域。

	颁布年份	法案名称	主要内容	链接
	2012	《欧盟基本权利宪章》	将个人数据权利提升到基本权利高度。	
数据保护	1981	《有关个人数据自动化处理的个人保护公约》（第108号公约）	对各成员国个人数据跨境流动进行了统一限制。	1. 中文版：（张余瑞） 📄 1.个人数据自动化处理中的个人保护公约（第108号公约）.pdf
	1995	《个人数据保护指令》 关于涉及个人数据处理的个人保护以及此类数据自由流通的第95/46/EC/号指令	对个人数据处理以及隐私保护做出规定。	1. 中文版： 📄 2.关于涉及个人数据处理的个人保护以及此类数据自由流通的指令.pdf
	2016	<u>《通用数据保护条例》</u> <u>(GDPR)</u>	严格限制用户数据的收集，规定了个人对数据的知情权、删除权、修	详细请参见 📄 通用数据保护条例 (GDPR)

			改权、被遗忘权等数据控制权利。	1. 正文：https://gdpr-info.eu/（第三方网站，但是UI做得特别好，条文与recital之间的链接完整，使用体验舒服） a. 全文英文版链接（PDF）： eur-lex.europa.eu b. 中文版： i. 纸质版推荐：李世刚、包丁裕睿、王峥编著，《欧盟一般数据保护条例文本和实用工具》，人民日报出版社 ii. 电子版： 1.GDPR_中文.pdf； 1.GDPR_中文（丁晓东译）.docx iii. 关于翻译问题，分享一则趣事，参见新江湾的周日：《GDPR第89条：一个有趣的翻译错误》
--	--	--	-----------------	---

			和开发利用激发数据要素市场活力。	
竞争与平台治理	2022	《数字市场法》 (Digital Market Act)	在原有竞争规则的基础上进行补充完善，赋予大型互联网平台“守门人”责任。	详细请参见 📖 数字市场法（DMA） 1. 原文： 📄 4.数字市场法_EN.pdf 2. 草案： 📄 9.数字市场法.pdf 3. 中文版： a. （中英对照版）“中美法律评论译” 📄 【中美法律评论】中文翻译首发 欧盟《数字市场法》全文公布.pdf b. （“数据信任与治理”出品）「全译本 欧盟《数字市场法》正式公布 c. 洪延青，《欧盟《数字市场法》生效版本-中文翻译》 4. 解读：赵精武，《从“超大型平台”到“守门人平台”：欧盟《数字市场法》的制度逻辑与监管特征》；蔡鹏等，《专业解读 数字市场法（DMA）——解析欧盟对大型数字平台的监管策略》
	2022	《数字服务法》 (Digital Service Act)	规制欧盟境内主体的在线中介服务提供者，对传输、缓存、处理、删除等数据中介服务进行管理。	详细请参见 📖 数字服务法（DSA） 1. 原文： 📄 CELEX_32022R2065_EN_TXT.pdf 2. 中文版： a. 朱悦， 📄 欧盟《数字服务法》译文.pdf b. 洪延青，《欧盟《数字服务法》生效版本-中文翻译（上）》；《欧盟《数字服务法》生效版本-中文翻译（下）》
网络安全	2019	《网络安全法》 (Cybersecurity Act)	创制了欧盟网络安全认证框架。	详细请参见 📖 网络安全法（Cybersecurity Act） 1. 原文： 📄 6.网络安全法_EN.pdf 2. 中文版： a. 吴沈括，黄伟庆译， 📄 6.网络安全法_中文.pdf b. 📄 5.2019网络安全法案.pdf
	2022	《网络弹性法（草案）》 (Cyber Resilience Act)	对数字产品从设计到投入市场到淘汰使用的全生命周期提出了网络安全要求。	1. 原文： 📄 7.网络弹性法案_EN.pdf 2. 中文版：数据治理与竞争法研究翻译， 📄 7.网络弹性法案_中文.pdf

【欧盟案例】

(2) 英国框架

目前，在英国，数据保护的主要法律是英国通用数据保护条例（UK GDPR）和 2018 年数据保护法（DPA）。DPA 2018 补充了英国 GDPR，例如，为处理特殊类别的个人数据提供了额外条件。DPA 2018 还为信息专员办公室（ICO）的权力和个人在法院投诉和寻

求救济的权利提供了框架。DPA 2018 还包含有关执法和情报机构处理个人数据的条款。

3.美国框架（以加州为主）

4.东南亚框架（以新加坡为主）

5.其他国家和地区（来源：[📖 DLaw Hub网站导航【先看】](#)）

[📖 域外地区法律概览](#) 包含了全球157个国家和地区的数据保护法律制度梳理，部分国家还会细分为[数据保护法律制度](#)和[人工智能法律制度](#)两个板块。

[📖 🏠 临时仓库](#) 临时存放最新的海外数据法的新闻

- [📖 欧洲](#)
- [📖 亚洲](#)
- [📖 中东](#)
- [📖 非洲](#)
- [📖 大洋洲](#)
- [📖 美洲](#)
- [📖 港澳台地区](#)
- [📖 🏠 临时仓库](#)

6.四个案例库（来源：[📖 DLaw Hub网站导航【先看】](#)）

- [📖 APP监管数据库](#)
- [📖 典型司法案例](#)
- [📖 行政执法案例库](#)
- [📖 告知同意实例库](#)

五、难点/问题/（未来可能）需要补充

- 周日：美国框架 中国框架2、3功能具体流程 输入输出真实材料收集 发群里
- 周一：美国框架 需提交文档的部分整理好 发群里
- 周二：知识库整理 发群里
- 周三：和开发同学对齐
- 周四：……

六、总结

暂无

参考材料

- [DLaw Hub数据法知识平台：http://www.dlawhub.com/](#)（这是我目前能找到的最全面的知识库，必用！）
- 律所解读：《数据出境新规密集来袭，你需要这份数据出境合规指南》（通商）
- 大成数据团队：《中国数据违规出境执法典型案例梳理与要点评析》<https://www.secrss.com/articles/87969>
- 君合法律评论《近期值得关注的数据出境监管案例》<https://www.junhe.com/legal-updates/2904>
- 跨国经营中的企业数据合规之道（vivo法务课程）<https://b23.tv/X9vPoJf>
- 【傅鹏：全球数据流通监管趋势，数据跨境合规超详细解读，法务律师必学，数据合规考试高分秘籍，零基础也能过！-哔哩哔哩】<https://b23.tv/87z296l>
- 傅鹏课程系列<https://www.bing.com/videos/riverview/relatedvideo?q=%e6%95%b0%e6%8d%ae%e5%90%88%e8%a7%84%e8%af%be%e7%a8%8b&mid=9D71F38461CF963372C39D71F38461CF963372C3&FORM=VIRE>
- 播客：硬核拆解跨境数据合规——解剖法律逻辑与交易实战作<https://www.xiaoyuzhoufm.com/episode/697cb2f6b4be4c149b4a598f>



中国互联网协会团体标准《数据跨境
合规流通体系建设指南》.pdf

421.47KB





企业数据合规指引与个人信息保护指
引.pdf

15.25MB



- 深圳市企业数据合规指引http://static-www.dgla.org.cn/file/upload/20241211/file/20241211141209_64a36a45c8244e768168f12686fcdc22.pdf
- 网信办：《数据出境安全评估申报指南（第三版）》https://www.szaicx.com/page142?article_id=19415
- 【合规搬运 | 对话数据合规法务总监-哔哩哔哩】<https://b23.tv/RndiTpZ>
- 【【全13讲+课件】数据资产全过程价值开发与合规风控-哔哩哔哩】<https://b23.tv/Kplyn4A>
- 【【全13讲+课件】数据资产全过程价值开发与合规风控-哔哩哔哩】<https://b23.tv/Kplyn4A>
- 【数据合规全实务应用手册---覆盖体系搭建、文书拟定、涉外网安、数据跨境等环节-哔哩哔哩】<https://b23.tv/qgrGB2o>
- 【傅鹏：全球数据流通监管趋势，数据跨境合规超详细解读，法务律师必学，数据合规考试高分秘籍，零基础也能过！-哔哩哔哩】<https://b23.tv/XEpcSC>
- 【EP025 | 傅鹏：硬核拆解跨境数据合规——解剖法律逻辑与交易实战-哔哩哔哩】<https://b23.tv/3FsD5O9>
- 【【合同相对论第43期】海问合伙人傅鹏律师：外如何玩转数据合规中的合同？ | 网络安全审查 | 数据合规-哔哩哔哩】<https://b23.tv/oEgqvQN>
- 【2022汽车出行行业数据合规总结-海问律师事务所-傅鹏-哔哩哔哩】<https://b23.tv/lmsMsni>
- 【数据法规讨论：欧洲GDPR vs 美国数据隐私法规-哔哩哔哩】<https://b23.tv/vhbXHPJ>
- 【60分钟详解GDPR The new EU General Data Protection Regulation in Under 60 Minutes!-哔哩哔哩】<https://b23.tv/3ovWPQl>
- 开放群岛开源社区跨境数据流通小组2025年11月发布的《跨境数据流通合规与技术应用白皮书(2025)》



跨境数据流通合规与技术应用白皮书
(2025) .pdf

4.01MB



- 《数据跨境时间探索白皮书》



数据跨境实践探索白皮书.pdf

588.06KB



- 《合规及跨境数据传输联合白皮书》



合规及跨境数据传输联合白皮书.pdf

3.22MB



- 《数据合规全攻略：法规解析.实践应用.数据资产探索》
- 《数据合规实务指引》
- 《数据百案分析》
- 《美国数据跨境流动管理的政策与实践》https://mp.weixin.qq.com/s/wgvjo8k4vjTxg1HY7kl_UQ
- 先前材料

